TECHNICAL REPORT

ANSI/ISA—TR99.00.02—2004
ANSI Technical Report prepared by ISA

Integrating Electronic Security into the Manufacturing and Control Systems Environment

Approved 10 October 2004

NOTICE OF COPYRIGHT
This is a copyright document and may not be copied or distributed in any form or manner without the permission of ISA. This copy of the document was made for the sole use of the person to whom ISA provided it and is subject to the restrictions stated in ISA's license to that person. It may not be provided to any other person in print, electronic, or any other form. Violations of ISA's copyright will be prosecuted to the fullest extent of the law and may result in substantial civil and criminal penalties.

ISA–The Instrumentation, Systems, and Automation Society

ANSI/ISA-TR99.00.02-2004

Integrating Electronic Security into the Manufacturing and Control Systems Environment

ISBN: 1-55617-889-1

Copyright © 2004 by ISA—The Instrumentation, Systems, and Automation Society. All rights reserved. Not for resale. Printed in the United States of America. No part of this publication may be reproduced, stored in a retrieval system, or transmitted in any form or by any means (electronic, mechanical, photocopying, recording, or otherwise), without the prior written permission of the Publisher.

ISA
67 Alexander Drive
P.O. Box 12277
Research Triangle Park, North Carolina 27709
USA

Preface

This preface, as well as all footnotes and annexes, is included for information purposes and is not part of ANSI/ISA-TR 99.00.02-2004.

This document has been prepared as part of the service of ISA--The Instrumentation, Systems, and Automation Society, toward a goal of uniformity in the field of instrumentation. To be of real value, this document should not be static but should be subject to periodic review. Toward this end, the Society welcomes all comments and criticisms and asks that they be addressed to the Secretary, Standards and Practices Board; ISA; 67 Alexander Drive; P. O. Box 12277; Research Triangle Park, NC 27709; Telephone (919) 549-8411; Fax (919) 549-8288; E-mail: standards@isa.org.

Publication of this ANSI Technical Report has been approved by the Accredited Standards Developer. This document is registered as a Technical Report series of publications according to the procedures for the Registration of ANSI Technical Reports. This document is not an American National Standard and the material contained herein is not normative in nature. Comments on the content of this document should be sent to the Accredited Standards Developer.

The ISA Standards and Practices Department is aware of the growing need for attention to the metric system of units in general, and the International System of Units (SI) in particular, in the preparation of instrumentation standards. The Department is further aware of the benefits to USA users of ISA standards of incorporating suitable references to the SI (and the metric system) in their business and professional dealings with other countries. Toward this end, this Department will endeavor to introduce SI-acceptable metric units in all new and revised standards, recommended practices, and technical reports to the greatest extent possible. *Standard for Use of the International System of Units (SI): The Modern Metric System*, published by the American Society for Testing & Materials as IEEE/ASTM SI 10-97, and future revisions, will be the reference guide for definitions, symbols, abbreviations, and conversion factors.

It is the policy of ISA to encourage and welcome the participation of all concerned individuals and interests in the development of ISA standards, recommended practices, and technical reports. Participation in the ISA standards-making process by an individual in no way constitutes endorsement by the employer of that individual, of ISA, or of any of the standards, recommended practices, and technical reports that ISA develops.

CAUTION — ISA ADHERES TO THE POLICY OF THE AMERICAN NATIONAL STANDARDS INSTITUTE WITH REGARD TO PATENTS. IF ISA IS INFORMED OF AN EXISTING PATENT THAT IS REQUIRED FOR USE OF THE DOCUMENT, IT WILL REQUIRE THE OWNER OF THE PATENT TO EITHER GRANT A ROYALTY-FREE LICENSE FOR USE OF THE PATENT BY USERS COMPLYING WITH THE DOCUMENT OR A LICENSE ON REASONABLE TERMS AND CONDITIONS THAT ARE FREE FROM UNFAIR DISCRIMINATION.

EVEN IF ISA IS UNAWARE OF ANY PATENT COVERING THIS DOCUMENT, THE USER IS CAUTIONED THAT IMPLEMENTATION OF THE DOCUMENT MAY REQUIRE USE OF TECHNIQUES, PROCESSES, OR MATERIALS COVERED BY PATENT RIGHTS. ISA TAKES NO POSITION ON THE EXISTENCE OR VALIDITY OF ANY PATENT RIGHTS THAT MAY BE INVOLVED IN IMPLEMENTING THE DOCUMENT. ISA IS NOT RESPONSIBLE FOR IDENTIFYING ALL PATENTS THAT MAY REQUIRE A LICENSE BEFORE IMPLEMENTATION OF THE DOCUMENT OR FOR INVESTIGATING THE VALIDITY OR SCOPE OF ANY PATENTS BROUGHT TO ITS ATTENTION. THE USER SHOULD CAREFULLY INVESTIGATE RELEVANT PATENTS BEFORE USING THE DOCUMENT FOR THE USER'S INTENDED APPLICATION.

Copyright 2004 ISA. All rights reserved.

HOWEVER, ISA ASKS THAT ANYONE REVIEWING THIS DOCUMENT WHO IS AWARE OF ANY PATENTS THAT MAY IMPACT IMPLEMENTATION OF THE DOCUMENT NOTIFY THE ISA STANDARDS AND PRACTICES DEPARTMENT OF THE PATENT AND ITS OWNER.

ADDITIONALLY, THE USE OF THIS DOCUMENT MAY INVOLVE HAZARDOUS MATERIALS, OPERATIONS OR EQUIPMENT. THE DOCUMENT CANNOT ANTICIPATE ALL POSSIBLE APPLICATIONS OR ADDRESS ALL POSSIBLE SAFETY ISSUES ASSOCIATED WITH USE IN HAZARDOUS CONDITIONS. THE USER OF THIS DOCUMENT MUST EXERCISE SOUND PROFESSIONAL JUDGMENT CONCERNING ITS USE AND APPLICABILITY UNDER THE USER'S PARTICULAR CIRCUMSTANCES. THE USER MUST ALSO CONSIDER THE APPLICABILITY OF ANY GOVERNMENTAL REGULATORY LIMITATIONS AND ESTABLISHED SAFETY AND HEALTH PRACTICES BEFORE IMPLEMENTING THIS DOCUMENT.

The following served as voting members of ISA-SP99:

NAME	COMPANY
B. Singer, *Chair*	Rockwell Automation
E. Hand, *Vice Chair*	Kraft Foods Inc.
R. Webb, *Managing Director & WG2 Leader*	Consultant
E. Byres, *Working Group 1 Leader*	British Columbia Institute of Technology
M. Franz, *Working Group 3 Leader*	Cisco Systems, Inc.
D. Teumim, *Working Group 7 Leader*	Teumim Technical LLC
P. Baybutt	Primatech Inc.
H. Beum	Interface Technologies
R. Bhojani	Bayer
D. Brandl	BR&L Consulting
K. Chambers	GE Fanuc Automation Americas Inc.
J. Christman	Northrop Grumman Information Technology
E. Cosman	The Dow Chemical Co.
J. Dalzon	ISA France
T. Davis	Telvent
R. Derynck	Verano Inc.
R. Dhaliwal	Allstream
R. Forrest	The Ohio State University
T. Good	DuPont
M. Heard	Eastman Chemical Co.
M. Lees	Schering-Plough Corp.
C. Mastromonico	Westinghouse Savannah River Co.
W. Matz	Invensys-Foxboro
G. Morningstar	Cedar Rapids Water Dept.
A. Nangia	3M
S. Oda	Yokogawa Corp. of America
R. Oyen	ABB Inc.
M. Schilt	Rockwell Automation
C. Sossman	WGI-W Safety Management Solutions LLC
L. Steinocher	Fluor Enterprises Inc.
B. Taylor	The George Washington University
D. Tindill	Matrikon Inc.
L. Uden	Lyondell/Equistar Chemicals
J. Weiss	KEMA Inc.

This technical report was approved for publication by the ISA Standards and Practices Board on 12 April 2004:

Copyright 2004 ISA. All rights reserved.

NAME	COMPANY
V. Maggioli, Chair	Feltronics Corp.
F. Amir	DuPont
D. Bishop	David N. Bishop, Consultant
K. Bond	Consultant
D. Bouchard	Paprican
M. Coppler	Ametek, Inc.
B. Dumortier	Schneider Electric
W. Holland	Consultant
E. Icayan	ACES, Inc.
A. Iverson	Ivy Optiks
T. McAvinew	Jacobs Engineering Group
A. McCauley, Jr.	Chagrin Valley Controls, Inc.
G. McFarland	Emerson Process Management
R. Reimer	Rockwell Automation
J. Rennie	Consultant
N. Sands	DuPont
H. Sasajima	Yamatake Corp.
T. Schnaare	Rosemount Inc.
A. Summers	SIS-TECH Solutions LLC
I. Verhappen	Syncrude Canada Ltd.
R. Webb	Consultant
W. Weidman	Parsons Energy & Chemicals Group
J. Weiss	KEMA Inc.
M. Widmeyer	Stanford Linear Accelerator Center
R. Wiegle	CANUS Corp.
C. Williams	Eastman Kodak Co.
M. Zielinski	Emerson Process Management

Copyright 2004 ISA. All rights reserved.

This page intentionally left blank.

Table of Contents

1 Scope 15

2 Purpose 15

3 Intended Audience 15

4 General Terms and Definitions 15

5 Background 17

6 Developing a Security Program 18

6.1 Leadership Commitment 18

6.2 Develop a Business Case 19

6.3 Develop a Charter or Scope 19

6.4 Program Tasks 20

6.5 Special Considerations for Manufacturing and Control Systems 21

6.6 Program Elements 22

6.7 Manufacturing and Control System Change Management Plan 31

6.8 The Security Lifecycle 34

6.9 Program Step Details 35

7 Define Risk Goals 36

8 Assess and Define Existing System 36

8.1 Form Cross-Functional Team 36

8.2 Pre-Risk Analysis Activities 36

8.3 Update the Screening Inventory 42

8.4 Make Preliminary Assessment of Overall Vulnerability 42

9 Conduct Risk Assessment and Gap Analysis 42

9.1 Conduct Detailed Risk Analysis Vulnerability Assessment of the Prioritized Assets 42

9.2 Prioritize Systems for Implementation Phase of Risk Mitigation Plan 54

10 Design or Select Countermeasures 55

10.1 Implement Risk Mitigation Strategies Based upon Detected Vulnerabilities 55

Copyright 2004 ISA. All rights reserved.

10.2 Address Vulnerabilities 59
10.3 Formalize Change Management Plan for the System 60
11 Procure or Build Countermeasures 60
11.1 Translate Requirements from Design Phase to Specification or Complete Construction 60
12 Define Component Test Plans 60
12.1 Decisions to Make When Planning a Test Program 60
12.2 Sufficient Testing 62
12.3 Component Test Plans 63
13 Test Countermeasures 63
14 Define Integration Test Plan 64
15 Perform Pre-Installation Integration Test 64
16 Define System Validation Test Plan 64
17 Perform Validation Test on Installed System 65
18 Finalize Operational Security Measures 65
18.1 Establish Operational Security Baseline 65
18.2 Finalize Operational Security Policy 66
18.3 Establish Management of Change (MOC) Program 66
18.4 Establish Periodic Audit Plan 66
18.5 Establish Audit Metrics 66
18.6 Establish Audit Metrics Reporting Procedure 66
18.7 Establish Compliance Requirements 67
18.8 Establish Corrective Action Procedures 67
18.9 Disaster Recovery 67
18.10 Monitoring and Logging 67
18.11 Intrusion Detection 67
18.12 Incident Response 67
18.13 Contingency Plans 68
18.14 Normal Support 68

Copyright 2004 ISA. All rights reserved.

18.15 Formalize Audit Plan for the System 68

18.16 Implement 69

19 Routine Security Reporting and Analysis 69

20 Periodic Audit and Compliance Measures 69

21 Reevaluate Security Countermeasures 69

22 Work with Suppliers and Consultants 69

22.1 System Suppliers 70

22.2 Consultants 70

22.3 Integrators 70

22.4 User Groups 70

23 Participate in Industry Forums and Development Programs 71

23.1 ISA—The Instrumentation, Systems, and Automation Society 71

23.2 U.S. National Institute of Standards and Technology (NIST) 71

23.3 North American Electric Reliability Council (NERC) 71

23.4 Chemical Industry Data Exchange (CIDX) 71

23.5 Institute of Electrical and Electronics Engineers (IEEE) 71

23.6 International Electrotechnical Commission (IEC) 71

23.7 International Council on Large Electric Systems (CIGRE) 72

23.8 U.S. Department of Energy National SCADA Test Bed Program 72

23.9 Process Control System Cyber Security Forum (PCSRF) 72

24 Bibliography and References 72

Annex A — Sample Policies and Procedures Document 75

Annex B — A Sample Vulnerability Assessment Procedure 87

Annex C —Integrating Security into Supplier Practices 87

Copyright 2004 ISA. All rights reserved.

This page intentionally left blank.

Foreword

In order to protect Manufacturing and Control Systems environments from potential threats and probability of attacks, each site or corporate entity should be responsible for developing an electronic security program and creating a security plan to protect manufacturing control networks.

This ISA Technical Report provides a framework for developing an electronic security program and provides a recommended organization and structure for the security plan. The information provides detailed information about the minimum elements to include. Site or entity-specific information should be included at the appropriate places in the program.

This technical report addresses Manufacturing and Control Systems whose compromise could result in any or all of the following situations:

- endangerment of public or employee health and safety
- loss of public confidence
- violation of regulatory requirements
- loss of proprietary or confidential information
- economic loss
- impact on entity, local, state or national security

The concept of Manufacturing and Control Systems electronic security is applied in the broadest practical sense, encompassing all types of plants, facilities, and systems in all industries. Manufacturing and Control Systems include, but are not limited to:

- Hardware and software systems such as Distributed Control Systems (DCSs), Programmable Logic Controllers (PLCs), Supervisory Control and Data Acquisition (SCADA) systems, networked electronic sensing, and monitoring and diagnostic systems
- Associated internal, human, network, or machine interfaces used to provide control, safety, and manufacturing operations functionality to continuous, batch, discrete, and other processes.
- Basic Process Control System (BPCS), Safety Instrumented System (SIS), and associated systems such as advanced or multivariable control, online optimizers, dedicated equipment monitors, and graphical interfaces.

Note to reader: ISA's SP99 standards development committee, which developed this ISA Technical Report, is seeking feedback on its content and usefulness. If you have comments on the value of this report or suggestions for improvements or additional topics, please send those comments by email, fax, postal, or phone to:

ISA-SP99
ISA Standards
67 Alexander Drive
Research Triangle Park, NC 27709 USA
Email: info@isa.org
Tel: +1 919 990 9200 Fax: +1 919 549 8288

Copyright 2004 ISA. All rights reserved.

This page intentionally left blank.

Introduction

This document, the second in a series of ISA Technical Reports, provides guidance to Manufacturing and Control Systems users (including operations, maintenance, engineering, and other user services), manufacturers, suppliers, and security practitioners, on how to provide adequate electronic (cyber) security for these systems. It focuses on the planning, developing, and implementing activities involved with a comprehensive program for integrating security into the Manufacturing and Control Systems environment. The program includes requirements, policies, procedures, and practices in areas ranging from risk analysis to management of change and compliance auditing.

Implementing this type of program often involves additional or changed hardware and software and may require training personnel on new technologies (such as network firewalls). Guidance on procedures in this area will involve some technology-related discussion and examples. This information is provided in the companion Technical Report in this series:

- **ANSI/ISA-TR99.00.01-2004, Security Technologies for Manufacturing and Control Systems**—Provides an overview of the types of electronic security technologies currently available to the Manufacturing and Control Systems environment; the pros, cons, and specific details of how each technology fits the environment; a list of types of products currently evaluated by the ISA-SP99 committee; and an idea of where security technology is headed in the future. A significant part of ANSI/ISA-TR99.00.02-2004, *Integrating Electronic Security into the Manufacturing and Control Systems Environment*, is technology-independent, but there are parts that rely on technology. Refer to ANSI/ISA-TR99.00.01-2004 for more comprehensive information on the alternatives available to implement security technologies.

Please refer to both technical reports in this series for a more comprehensive presentation and understanding of the technology, programs, and audits and testing necessary to provide electronic security to the Manufacturing and Control Systems environment.

This ISA technical report provides guidance for attaining adequate electronic security. It should be used to help identify and address vulnerabilities and reduce the risk of undesired intrusions that could compromise confidential information or cause disruption or failure of manufacturing or control systems.

The guidance presented in this document is general in nature, and must be applied to each system or network by personnel knowledgeable in the manufacturing or control systems to which it is being applied. The guidance identifies those activities, system attributes, and actions that are typically important to provide electronically secure control systems, but whose application is not always compatible with maintenance of a system's functions. Guidance includes suggestions on appropriate application to specific control systems; however, selection of activities and practices for a given system is the responsibility of the system's owner.

It is expected that this guidance will grow and change over time, as experience is obtained with system vulnerability and security and new technologies become available. While the general format of this guidance is expected to remain relatively stable, the specifics of its application and specific solutions are expected to evolve with developments in technology, industry requirements, and regulatory requirements.

Copyright 2004 ISA. All rights reserved.

This page intentionally left blank.

1 Scope

The scope of this ISA technical report includes Manufacturing and Control Systems whose compromise could result in the endangerment of public or employee health or safety, loss of public confidence, violation of regulatory requirements, loss or invalidation of proprietary or confidential information, or economic loss. The concept of Manufacturing and Control Systems electronic security is applied in the broadest practical sense, encompassing all types of manufacturing and process facilities and systems in all industries. Manufacturing and Control Systems include, but are not limited to:

- Hardware and software systems such as Distributed Control Systems (DCSs), Programmable Logic Controllers (PLCs), Supervisory Control and Data Acquisition (SCADA) systems, networked electronic sensing systems, and monitoring and diagnostic systems;

- Associated internal, human, network, or machine interfaces used to provide control, safety, and manufacturing operations functionality to continuous, batch, discrete, and other processes.

Enterprise Resource Management and Enterprise Resource Planning Systems are not within the scope of this document, although the integrity of data communications from the Manufacturing and Control Systems domains into the Enterprise Resource Business Systems should be included.

2 Purpose

The purpose of this ISA technical report is to present a consistent approach for developing, implementing, and operating a program that addresses security for Manufacturing and Control Systems.

3 Intended Audience

The audience for this ISA technical report includes all users of Manufacturing and Control Systems (including facility operations, maintenance, engineering, and corporate components of user organizations), manufacturers, suppliers, and security practitioners.

4 General Terms and Definitions

While the following terms can take on various interpretations, the definitions in this section are used to show how they apply to this technical report.

Component Testing—Testing performed by a vendor, a user's plant, or an outside lab to assure all parties that the purchased security components will meet the purchase specifications and will demonstrate the required security performance.

Compromise—Any action from authorized or unauthorized sources that results in the undesirable release of confidential information, modification of critical information, loss of control over system or component assets, physical endangerment, loss of system availability, degraded monitoring capability, or decreased reliability of Manufacturing and Control Systems, or their informational dependencies.

Control System Operations—Control system operations encompass the collection of production, maintenance, and quality assurance operations with other activities of a manufacturing facility. They include:

- facility activities that coordinate the personnel, equipment, and material involved in the conversion of raw materials into end products

Copyright 2004 ISA. All rights reserved.

- functions that may be performed by physical equipment, human effort, and information systems

- managing information about the schedules, use, capability, definition, history, and status of all of the resources (personnel, equipment, and material) within a facility.

Integration Testing—The examination and testing of several security components, perhaps from different vendors, temporarily connected together in a test environment to see if the security components will work together correctly before being placed in an actual Manufacturing and Control System.

Manufacturing and Control Systems—Systems (personnel, hardware, and software) comprised in either standalone or networked configurations, designed to control or monitor specific aspects of a production process, including safety. Production includes conveyance, treatment, processing, manufacturing, distribution, or engineering of the production process for any product including, but not limited to, utilities production and distribution, consumer goods, raw materials, component parts, and the like. Manufacturing and Control Systems can include DCS, HMI, PLC, SCADA, hybrid, or any other type of control system serving any part of a manufacturing process and utility industries including continuous, discrete, batch, or other processes.

Manufacturing and Control Systems Electronic Security—Manufacturing and Control Systems Electronic Security includes the concepts of identification, authentication, accountability, authorization, and privacy. The objective is to preclude unauthorized use, modification, disclosure, or destruction of critical systems or informational assets in an effort to reduce the risk of personal injury or possibility of endangering public health, loss of public or consumer confidence, disclosure of sensitive assets, and protection of business assets. These concepts are applied to any system in the production process and include both standalone and networked components. Communications between systems may be either through internal messaging or by any human or machine interfaces that authenticate, operate, control, or exchange data with any of these control systems.

Manufacturing Operations—Manufacturing operations encompass the collection of production, maintenance, and quality assurance operations with other activities of a production facility. Operations include:

- manufacturing or processing facility activities that coordinate the personnel, equipment, and material involved in the conversion of raw materials and/or parts into products

- functions that may be performed by physical equipment, human effort, and information systems

- managing information about the schedules, use, capability, definition, history, and status of all resources (personnel, equipment, and material) within the manufacturing facility.

Security Components (also called Security Countermeasures)—Techniques such as firewalls, authentication modules, or encryption software purchased from outside security vendors for insertion into the existing Manufacturing and Control System to improve the security performance of that system.

Security Guidelines—Security guidelines define the objectives and constraints for a security program. Guidelines are created at several levels, ranging from company or corporate policy to specific operational constraints (e.g., remote access). In general, guidelines provide answers to the questions “what” and “why” without dealing with “how.” Guidelines are normally stated in terms that are technology-independent.

Security Performance—Security performance may be evaluated in terms of a program’s compliance, completeness of measures to provide specific threat protection, post-compromise analysis, review of changing business requirements, new threat and vulnerability information, and periodic audit of control systems to ensure that security measures remain effective and appropriate. Tests, audits, tools, measures, or other methods are required to evaluate security practice performance.

Copyright 2004 ISA. All rights reserved.

Security Practices—Security practices provide a means of capturing experiences and activities that help ensure system protection and reduce potential Manufacturing and Control Systems compromise. Subject areas include physical security, procedures, organization, design, and programming. Security practices include the actual steps to be taken to ensure system protection.

Security Procedures—Security procedures define exactly how practices are implemented and executed. They are implemented through personnel training and actions using currently available and installed technology (such as disconnecting modems). Procedures and contained criteria also include more technology-dependent system requirements that need careful analysis, design, planning, and coordinated installation and implementation.

Security Program—A security program brings together all aspects of managing security, ranging from the definition and communication of guidelines through implementation of best industry practices and ongoing operation and auditing.

System Validation Testing—Testing done on the entire Manufacturing and Control System after all security components are inserted, configured, and made operational. The Manufacturing and Control System may have to be in a non-production mode, such as turnaround mode, to conduct this testing. The purpose of system validation testing and assurance is to see whether the entire Manufacturing and Control System, with new security components retrofitted, will meet the desired security performance while still meeting the non-security functional performance requirements and specifications.

Teleworking—Teleworking is an arrangement through which employees work from a location away from their employer's main office. Electronic connections (e.g., telephone lines, cellular/wireless circuits, Internet access) are relied upon for the bulk of interactions and information transfer.

5 Background

During the past several years, process automation systems that support the process and manufacturing enterprise have evolved from individual, isolated computers with proprietary operating systems and networks to interconnected systems and applications employing widely used and well understood “open systems” technology (i.e., operating systems and protocols). These automation systems are now being integrated with enterprise systems and other business applications through site and corporate communication networks. This integrated architecture provides significant business benefits including the following:

- Increased visibility of shop floor activities (work in process, equipment status, production schedules), enabling improved business analysis and decision making.

- Integrated manufacturing systems that have more direct access to and from enterprise information, enabling a more responsive manufacturing enterprise.

- Common interfaces that reduce overall support costs and permit remote support of production processes.

- Improved data accessibility that provides the ability to conduct analyses to drive out production costs and improve productivity.

- Remote monitoring of the process control systems that allows problems to be solved more quickly and reduces support costs.

ANSI/ISA standards, such as the ANSI/ISA-50 (Fieldbus) series, ANSI/ISA-84 (Application of Safety Instrumented Systems for the Process Industries) series, ANSI/ISA-88 (Batch Control) series, ANSI/ISA-91.00.01-2001 (Identification of Emergency Shutdown Systems and Controls that Are Critical to

Copyright 2004 ISA. All rights reserved.

Maintaining Safety in Process Industries), and ANSI/ISA-95 (Enterprise-Control System Integration) series, have added considerable value to the Manufacturing and Control Systems community by establishing models, terms, and information exchanges that provide the ability to share information in an open and standardized way (visit www.isa.org/standards/ for additional information on these standards). However, this ability to exchange information increases vulnerability to misuse and attack by individuals with malicious intent and introduces potential risks to the enterprise that uses Manufacturing and Control Systems.

In recent years, electronic security has become a more significant and widely acknowledged concern. People with knowledge of features provided by open operating systems and networks could potentially intrude into console devices, remote devices, databases and, in some cases, control platforms. The impact of intruders on Manufacturing and Control Systems may include:

- unauthorized access, theft, or misuse of confidential information
- loss of integrity or reliability of process data and production information
- loss of system availability
- process upsets leading to inferior product quality, lost production capacity, compromised process safety, or environmental releases
- equipment damage
- personal injury
- violation of legal and regulatory requirements
- public health and confidence
- impact on a nation's security.

The focus on unauthorized access has broadened from "hackers" or disgruntled employees to include deliberate terrorist activities aimed at harming large groups and facilities. This shift requires a more structured set of guidelines and procedures to define electronic security applicable to Manufacturing and Control Systems, as well as the respective connectivity to other systems.

6 Developing a Security Program

Effectively integrating security into a Manufacturing and Control System environment requires defining and executing a comprehensive program that addresses all aspects of security, ranging from identifying objectives to day-to-day operation and ongoing auditing for compliance and improvement. This section describes the basic process for developing a security program. More detailed information on the various steps is provided in subsequent sections.

6.1 Leadership Commitment

The commitment to a security program begins at the top. Senior management must demonstrate a clear commitment to cybersecurity. Cybersecurity is a business responsibility shared by all members of the enterprise and especially by leading members of the business, process, and manufacturing management teams. Cybersecurity programs with visible, top-level support and "buy-in" from organization leaders are more likely to gain compliance, function more smoothly, and have earlier success.

Copyright 2004 ISA. All rights reserved.

6.2 Develop a Business Case

Even with a general commitment, upper management does not always recognize or understand the practical benefits of cybersecurity for Manufacturing and Control Systems. In order to obtain funding, it may be necessary to build a business case. *The ISA-SP99 committee recognizes this topic as important and will address it further in a future revision of this Technical Report.*

6.3 Develop a Charter or Scope

With the imperative understood and the business case established, the next step is to develop a formal charter or scope for the effort. This charter should explain clearly what is to be accomplished (in business terms) and when. The scope of the program defines the specific entity (business, site, or corporation) of focus.

The charter should be owned by a senior executive program champion who will be responsible for guiding the team during program development. The champion will ultimately be responsible for making sure that the program is executed, including communications, enforcement, and auditing.

6.3.1 Assemble Stakeholders and Establish a Program Team

The next step is to assemble the team of people responsible for developing the various program elements, including guidelines, processes, and procedures. The team should consist of, but not be limited to, personnel from the following areas:

- Information Technology (IT)
- Telecommunications
- Process Control
- Operations and Production
- Maintenance
- Security
- Management
- Training
- Human Resources
- Finance

Programs should be developed so that they can be implemented throughout a specific entity (business, site, or corporation). The initial program scope is defined when the program team is formed, but may have to be adjusted as the team's knowledge grows.

Programs should be developed within existing business, site, or corporation program structures as appropriate to simplify and expedite the process.

Copyright 2004 ISA. All rights reserved.

A senior executive program champion should be responsible for guiding the team during program development. The champion will ultimately be responsible for making sure that the program is executed, including communications, enforcement, and auditing.

6.4 Program Tasks

Once the team has been assembled, its first activity is to plan the basic tasks that must be accomplished in developing an effective program. These tasks are briefly described in the following paragraphs. More detailed information is provided in sections 7 through 21.

1. **Define Risks**

   The first task for the program team is to define the potential risks for the Manufacturing and Control System. Risks may be identified through a variety of means, ranging from corporate governance or external regulatory compliance to the application of a formal risk assessment methodology. Regardless of how they are identified, risks must be categorized and prioritized.

2. **Establish Program Goals**

   Establish specific goals to address the risks identified. These goals form the foundation of the security program and must be clearly supported by senior management, as well as the technical experts responsible for Manufacturing and Control Systems.

   Goals should include developing an implementation plan and schedule including all aspects of the program, along with recommendations for developing awareness and training all personnel. The implementation plan includes a transition phase that provides the methodology and architecture to get from the “as-is” security conditions to the “to-be” security conditions. It also provides the details of actually performing the work required to make the security changes and additions to the Manufacturing and Control Systems. The schedule may depend on funding the program, but should consider the priorities defined in the plan.

3. **Identify Program Elements and Develop a Plan**

   Security programs consist of various combinations of written guidelines, standards, processes, and procedures that address the issues and requirements within the stated scope of the program. Written documentation must clearly state whether actions and procedures are mandatory or recommended practices.

   Each program requires a specific list of elements to be included. These elements build on existing Information Technology (IT) security experience, programs, and practices, but are tailored to the specific security requirements of the Manufacturing and Control System environment. A list of possible elements can be found in section 6.6.

4. **Address Configuration Management**

   Vital information and assets must be assessed and classified based on the consequences of loss, damage, or failure. Assign the appropriate levels of security protection and assess the vulnerability of Manufacturing and Control System information loss or compromise.

5. **Establish Performance Considerations**

   When developing an electronic security program, it is important to consider various aspects of Manufacturing and Control System performance to ensure that each element is applied without adversely impacting the systems to which it is applied. However, it is also essential to review and consider the required performance at an overall systems level to ensure that when all security

Copyright 2004 ISA. All rights reserved.

features are taken together, they do not adversely affect required time-critical or other performance characteristics of these systems.

Successful completion of this task requires a detailed understanding of the factors that make Manufacturing and Control Systems different from typical business information technology systems. Special considerations for Manufacturing and Control Systems are examined in more detail in section 6.5.

6. Execute the Program

A complete program includes plans that define the approach to and criteria for Manufacturing and Control Systems electronic security. Plans define how necessary security is provided, and usually include functional requirements, as well as certain specific technical requirements. They provide for the system's electronic security, while ensuring that the basic manufacturing and control functionality is fully met. Plans encompass all aspects of the program; they define the program in its entirety, even though the plans may be performed or implemented throughout the organization, (e.g., design, engineering, IT services, operations, maintenance, procurement).

6.5 Special Considerations for Manufacturing and Control Systems

Manufacturing and Control System electronic security plans and programs are consistent with, and build on, existing IT (information technology) security experience, programs, and practices. However, there are critical operational differences between IT and Manufacturing and Control Systems that influence how specific measures should be applied. Key differences include:

- **Differing risk management goals**—Human safety and fault tolerance to prevent loss of life or endangerment of public health or confidence, loss of equipment, loss of intellectual property, or lost or damaged product.

- **Differing architecture security focus**—In a typical IT system, the primary focus of security is protecting the information stored on the central server. In manufacturing systems, the situation is reversed. Edge clients (e.g., PLC, operator station, or DCS controller) are typically more important than the central server.

- **Differing availability requirements**—Many manufacturing processes are continuous in nature. Unexpected outages of systems that control manufacturing processes are not acceptable. Exhaustive pre-deployment testing is essential to ensure high availability for the Manufacturing and Control System. In addition to unexpected outages, many control systems cannot be easily stopped and started without affecting production. In some cases, the products produced or equipment being used is more important than the information being relayed. The requirement for high availability, reliability, and maintainability reduces the effectiveness of IT strategies like rebooting.

- **Unintended consequences**—Manufacturing and Control Systems can be very complex in the way that they interact with physical processes. All security functions integrated into the process control system must be tested to prove that they do not introduce unacceptable vulnerabilities. Adding any physical or logical component to the system may reduce reliability of the control system, but the resulting reliability should be kept to acceptable levels.

- **Time critical responses**—For some systems, automated response time or system response to human interaction is critical. For example, emergency actions on regulatory process control systems should not be hampered by requiring password authentication and authorization. Information flow must not be interrupted or compromised.

Copyright 2004 ISA. All rights reserved.

- **Differing response time requirements**—Manufacturing and Control Systems are generally time critical; delay is not acceptable for the delivery of information, and high throughput is typically not essential.

- **System software**—Differing and "custom" operating systems and applications may not tolerate typical IT practices. Networks are often more complex and require a different level of expertise (e.g., control networks are typically managed by control engineers, not IT personnel). Software and hardware applications are more difficult to upgrade in a control system network. Many systems may not have desired features including encryption capabilities, error logging, and password protection.

- **Resource constraints**—Control systems and their real time operating systems are resource-constrained systems that do not include typical IT security technologies. There may not be available computing resources to retrofit these security technologies.

- **Information integrity**—In-bound information is highly essential to the control system operation. It is important to take practical precautions to eliminate malicious in-bound information in an effort to maintain control operation.

- **Communications**—Communication protocols and media used by control systems environments are typically different from the generic IT environment, and may be proprietary. Examples include radio telemetry using asynchronous serial protocols and proprietary communication networks.

- **Software Updates**—Security patches cannot always be implemented on a timely basis because software changes need to be thoroughly tested by the vendor of the manufacturing control application and the end user of the application before being implemented. Change management control is necessary to maintain integrity of the control systems.

These differences require careful assessment by Manufacturing and Control System experts working in conjunction with security and IT personnel. This team of people should carefully evaluate the applicability of IT and specific Manufacturing and Control Systems electronic security features, including thorough testing before application, where necessary.

6.6 Program Elements

There are several specific elements that are delivered as part of a comprehensive security program. These elements should be carefully documented. Written records should be kept of all policies and procedures, as well as all results of their application. Backups or archives should be maintained so that failures or compromise of the systems will not destroy records.

The following paragraphs describe several elements that are commonly included in such a program.

6.6.1 Definitions

Provide a set of definitions for all key words and phrases, especially as they apply to Manufacturing and Control Systems.

6.6.2 Scope and Purpose

A description of the program's scope and purpose is typically taken from the initial charter. The security perimeter of the hardware and software to which the program is to be applied should also be defined. Defining the security perimeter supports a clear understanding of all connections and interfaces that must be secure.

Copyright 2004 ISA. All rights reserved.

6.6.3 Organization Responsibilities

Define the roles and responsibilities for the entire organization, along with interfaces between each part of the organization. This structure allows all participants to clearly understand their role and the role of others with whom they must interface at all levels.

The organization responsible for Manufacturing and Control Systems may be different from that responsible for IT systems. The organization may have different priorities with established training procedures focused on legal compliance, preventing accidents, controlling incidents, maintaining product quality, and preventing loss of revenue.

6.6.4 Principles

The security program should develop or identify principles for process control security that balance the needs of both production and corporate security. Examples of where principles may be required include:

- Ownership and accountability—how are these assigned within the organization?
- Operation and production requirements.
- Support needs and strategies.
- Access control.
- Physical security.
- Monitoring and controlling physical features.
- Physical access control, locking, and protection.
- Maintenance management.

6.6.5 Vulnerability Assessment

Every business organization should identify its vital information and assets, classify them based on the consequences of loss or failure, assign appropriate levels of security protection, and assess the vulnerability of its Manufacturing and Control Systems to information loss or compromise. Once system vulnerabilities are understood, the security program can be designed to take the appropriate actions to ensure that levels of security protection are achieved through both system design and administrative controls.

6.6.6 Policies

In response to the principles and management direction, the program team must identify or develop a series of polices that determine exactly how security is to be managed. These policies will exist at several levels, ranging from basic organizational policies that are established by management to more detailed policies that pertain to specific aspects of the program. The appropriate level of management must understand and approve all policies. Potential areas requiring policies include:

- Legal and regulatory compliance
- Training and certification

Copyright 2004 ISA. All rights reserved.

- Hiring, evaluating and terminating personnel
- Assignment of appropriate security clearance levels
- Authentication
- Authorization
- Logical rights
- Change control
- Logging
- Passwords
- Accounts
- Modem access
- Other remote access
- Unused resources

Annex A provides an example set of security policies and practices developed to support the security risk goals and overall security program for one company's Manufacturing and Control Systems environment. These examples are provided to illustrate the level of policy and practice decisions that need to be made to support meeting the risk goals.

6.6.7 Standards

In addition to principles and policies, specific standards must be identified or established under the security program. Areas where standards may exist or be required include:

- Communication protocols
- Network architecture
- Operating systems
- Databases
- Safety
- Physical installations
- Maintenance
- Security clearance parameters

In some cases, the standards selected may be the same as those applied to business IT systems. However, there will be situations where different standards are selected to meet the specific needs of manufacturing systems.

Copyright 2004 ISA. All rights reserved.

6.6.8 Design Models

The security program may include developing design models to describe the minimum acceptable or recommended practices to be used in constructing a secure system. Topics that could be addressed through the use of models include:

- System hardware and software design and implementation requirements, such as the use of firewalls, routers, and switches
- Permissible data flows
- Management activities to ensure compliance with the requirements

While the focus of models is on meeting functional requirements, some technology is suggested in these discussions and guidance to provide examples and ensure understanding. ANSI/ISA-TR99.00.01-2004*, Security Technologies for Manufacturing and Control Systems,* provides a more comprehensive listing of available technologies to meet these requirements, along with recommendations for use in the Manufacturing and Control System environment. ANSI/ISA-TR99.00.01-2004 should be used in conjunction with the requirements and solutions developed in accordance with this technical report.

Several models will be required in any program.

6.6.8.1 Network Segments

The network in a modern manufacturing facility is typically comprised of a series of logical and physical network segments that represent a “layers of protection” approach to design. The specific names used for these segments will vary, but the general arrangement will be similar to the following:

- **Enterprise Network Segment**—Enterprise system computers, such as Enterprise Resource Planning (ERP), Supply Chain Management (SCM), and Customer Relationship Management (CRM) computers are connected on this segment. General-purpose internal client systems (desktops and laptops) also typically connect here.
- **Process Information Network Segment**—Manufacturing Execution System (MES) computers are connected to the process information network segment. This network segment is connected to the enterprise network via routers, but sometimes shares the network with enterprise network segment.
- **Control Network Segment**—Controllers and Human Machine Interface (HMI) devices for manufacturing control are connected on this segment. Media and protocols may be proprietary or general-purpose. Primitive, but essential, information for control is exchanged, such as measured variables and manipulating variables; sometimes controller configuration information is exchanged for maintenance purposes. Communication frames designated to field network may also use this network. The control network is usually connected to the information network via a gateway or similar device and may be further isolated by means of a firewall.
- **Field Network Segment**—Field devices, such as sensors and actuators, are connected on this network segment. Usually proprietary protocols and/or media are used for communication and the connected devices usually have less computing capability. Primitive, but essential, information for control is exchanged, such as measured variables and manipulating variables; sometimes controller configuration information is exchanged for maintenance purposes. The field network is usually connected to the control network via a controller or gateway.

Copyright 2004 ISA. All rights reserved.

- **Process Segment**—The most elementary segment consists of pipe, valves, vessels, transport belts, and vehicles containing the production fluid or product devices. These segments are entirely physical and provide the means to attach the primary element sensors mentioned under field network segment. Although this segment is not directly impacted by information system vulnerabilities, it could be impacted indirectly by the control systems or by intentional human interaction, and thus must also be considered.

This technical report focuses on the process information network, control network, and field network security. The enterprise network should be protected by IT and business policies; process segments and the physical plan should be protected by a physical security plan that is beyond the scope of this document.

6.6.8.2 Access Control Model

The Access Control Model describes the recommended practices for accessing Manufacturing and Control Systems. Because there are various segments in the network model, there may be varying access control practices for devices on the different network segments. When applying access control, make sure to recognize the unique aspects of Manufacturing and Control Systems. For example, operators in a control room typically need to be able to operate the plant and take control actions, often immediately, without any hindrance from passwords. Physical security and trustworthy personnel are assumed to ensure that operators can perform needed actions immediately. However, the need to modify or reconfigure the system on such an immediate basis is not likely to be required, and therefore stronger access controls could be used to ensure that the person is authorized to perform this function.

6.6.8.2.1 User Access Management

Access Management addresses policies and practices for managing user accounts at the different network segment levels. Develop policies for the following aspects of managing user accounts. Follow ISO 17799:2000[1], 9.2 as appropriate regarding user account management.

- User registration
- Privilege management
- User password management
- Review of user access rights

6.6.8.2.2 User Responsibilities

Users on different network segments may have different responsibilities. The vulnerabilities and risks at different network segment levels require that different policies and practices be created for the following aspects of the information network. Develop policies for the following aspects of user responsibilities. Follow ISO 17799:2000, 9.3 as appropriate.

---

[1] ISO 17799, *Information Technology—Code of Practice for Information Security Management*, was developed for traditional IT systems. Many of the recommendations, including password policies, may not be appropriate for control system applications.

Copyright 2004 ISA. All rights reserved.

- Password use
- Unattended user equipment

6.6.8.2.3 Network Access Control

The security program must include policies and practices for the following aspects of the information, control and field network segments and all devices connected to them. Develop policies for the following aspects of network access control. Follow ISO 17799:2000, 9.4 as appropriate.

- Policy on the use of network services
- Enforced path
- User authentication for external connections
- Node authentication
- Remote diagnostic port protection
- Network connection control
- Network routing control
- Security of network services

Control Networks and Field Networks should be physically secured. Refer to section 6.6.8.3, "Physical and Environmental Security."

6.6.8.2.4 Operating System Access Control

Develop policies for the following aspects of the network, including gateways that connect network segments. Follow ISO 17799:2000, 9.5 as appropriate.

- Automatic terminal identification
- Terminal log-on procedures
- User identification and authentication
- Password management system
- Use of system utilities
- Duress alarm to safeguard users
- Terminal time-out
- Limitation of connection time

6.6.8.2.5 Application Access Control

Copyright 2004 ISA. All rights reserved.

Develop policies for the following aspects of the network, including gateways that connect network segments. Follow ISO 17799:2000, 9.6 as appropriate.

- Information access restriction
- Sensitive system isolation

6.6.8.2.6 Monitoring System Access and Use

Develop policies for the following aspects of the network. Also develop policies for the external equipment if the control network or field network has external access points. Follow ISO 17799:2000, 9.7.

- Cyber event logging
- Monitoring system use

The following events should be logged and monitored for control networks:

- Data access
- Other events related to system security and/or network-based intrusion, as appropriate.

6.6.8.2.7 Remote Access and Teleworking

The security program must address the remote or mobile user who attempts to access the network. Policies and practices are required to address the type of connection (wireless-based, Internet-based, dial-in modem-based, LAN, WAN), as well as the functions that may be performed by the remote or mobile user. Follow ISO 17799:2000, 9.8 as appropriate.

Mobile computing access to manufacturing systems should be closely controlled. The security program should include developing security policies and practices for using mobile access points. Examples of possible direction include:

- User accounts for mobile computing should not be shared with non-mobile use.
- Password aging and lockout should be used for mobile user account management.
- All activities through mobile access points should be logged and monitored.
- Access points should be accessed via closed network connections only. Closed network connections include IP-VPN service.

6.6.8.3 Physical and Environmental Security

The control and field network segments should be strictly physically secured. Based on results of security assessments performed to date, the security perimeter may have to be defined on a case-by-case basis.

During security program implementation, the security perimeter for the Manufacturing and Control System should be defined, specifying the components that make up the security boundary for the system. The security boundary usually provides several layers of protection and typically extends beyond the immediate Manufacturing and Control System design to include external applications and communications networks.

Copyright 2004 ISA. All rights reserved.

There are several possibilities for defining the physical perimeter, depending on the circumstances and company practice. For example, in a large integrated manufacturing site that includes multiple operating units, it may be the practice to establish the perimeter at the fence line, treating all units as part of one physical facility. This design would clearly not be appropriate in cases where multiple companies share a physical site, as is the case in a typical industrial park. In that situation, the physical perimeter could be defined at the unit level. In general terms, the physical perimeter is defined in terms of a contiguous area owned by a single entity.

Develop policies for the following aspects of physical security. Follow ISO 17799:2000, 7 as appropriate.

- Security areas
- Equipment security
- General controls

6.6.8.4 Communications and Operations Management

Develop policies for the following aspects of the Information Network. Follow ISO 17799:2000, 8 as appropriate.

- Operational procedures and responsibilities
- System planning and acceptance
- Protection against malicious software
- Housekeeping
  - Information back-up
  - Operator logs
  - Fault logging
- Network management
- Media handling and security
  - Management of removable or attachable computer media
  - Disposal of media
  - Information handling procedures
  - Security of system documentation
  - Exchanges of information and software

6.6.8.5 Performance Considerations

Every element of the policy provides for considerations of Manufacturing and Control System performance to ensure that each element is applied without adverse impact on the systems to which it is

Copyright 2004 ISA. All rights reserved.

applied. However, it is also essential to review and consider the required performance at an overall systems level to ensure that all security features, when taken together, do not adversely affect required time-critical system performance and other functions. Functions to consider regarding performance include:

- Overhead time and reliability of firewalls and authentication
- Overhead time and reliability of authentication and authorization functions
- Overhead time and reliability in encrypting and decrypting
- Interoperability

6.6.9 Development Systems

Most Manufacturing and Control Systems employ two models for development and configuration change:

- Online development (run-time changes)
- Offline development tools and systems

Online development tools may allow minor changes to be made to the currently executing applications. While this approach may be valuable in reducing production interruptions and optimizing product parameters, it also adds a degree of risk, especially when development is performed remotely. Cybersecurity-associated risks with unsecure connections or weak authenticated users create one type of risk, but there are other significant risks associated with not being physically present in the Manufacturing and Control area when making online changes.

Good security practices must be followed on offline development tools and systems as well. Because these systems may directly load configuration or application files to the online running Manufacturing and Control Systems, special care must be taken to ensure that good security practices are followed.

The overall security policy must consider the increased potential for Manufacturing and Control Systems compromise or failure associated with development and configuration tools used and shall preclude such features or connections where these risks are not acceptable.

6.6.10 Living Program

The overall corporate security program must incorporate periodic reviews of all security initiatives and processes in order to verify that they are in place and working. Corrective action must be taken as appropriate to adapt to changing threats, legal requirements, and user needs and incorporate electronic security technology improvements.

6.6.11 Industry Participation

A good security program should incorporate knowledge from outside the company to supplement internally developed program elements, security polices, and security practices. Key security program participants should participate in appropriate industry groups and forums. These groups include sector-lead organizations, standards organizations, vendor organizations, and other groups that provide knowledge sharing on how systems have been compromised, response approaches, and successful programs, policy, and technology.

Copyright 2004 ISA. All rights reserved.

6.7 Manufacturing and Control System Change Management Plan

After the security program is designed, the Manufacturing and Control System change management plan should be developed and implemented. The change management plan is required to establish the methods, activities, roles, and responsibilities for maintaining the required levels of operation, safety, and security protection throughout the life cycle phases of the system. Modifications and upgrades should be made to include new manufacturing operations or replace or add new control equipment. When these changes occur, the Manufacturing and Control System should repeat a review of all the required levels of security protection throughout the life cycle phases of the system. Typical life cycle phases include requirement specification, design, implementation, testing, installation, operation and maintenance, and retirement. The change management plan needs to define all the steps to be followed to ensure that operations, safety, and security are not compromised.

The security boundary and scope of a Manufacturing and Control System should be defined in the broadest sense. The change management plan should identify each component in the security boundary. The security boundary typically includes those items identified in the security vulnerability and risk assessment that are identified as a source of vulnerability and those that are credited with providing the required level of protection for one or more vital information sources or assets. These items may involve hardware (physical), software (electronic) and administrative (procedures, policies, training) components, including the items specified below.

6.7.1 Hardware Assets and Components (Physical)

One class of assets to include in the change management plan involves the hardware devices within the security boundary. Some examples are as follows:

- Computer hardware (workstations, servers, instruments, controls, power supplies, disk drives, and tape backups)
- Network equipment, such as routers, switches, hubs, firewalls, and physical cables
- Communications links (buses, links, modems, and other network interfaces, and antennas)
- Access authentication and authorization equipment, such as domain controllers, radius servers, readers, and scanners
- Development system hardware
- Simulation/training system hardware
- External system hardware
- Spare parts inventories.

6.7.2 Software Assets and Components (Electronic)

Additional assets to include in the change management plan are the software components within the security boundary. Some examples are as follows:

- Computer system software (applications, operating systems, external application, communication interfaces, configuration tables, development tools, analysis tools, and utilities)
- Patches and upgrades for operating systems and application tool sets

Copyright 2004 ISA. All rights reserved.

- Change management software for patch distribution and application upgrades
- Development system software
- Simulation software
- External system applications
- Databases
- Data archives
- Network equipment configuration files
- Access authentication and authorization control applications
- Backup and recovery media (CDs, disks, tapes)
- Design basis documentation (functional requirements including information/assets, security classification, and levels of protection, physical and software design, vulnerability assessment, security perimeter, benchmark tests, and assembly/installation documents)
- Supplier resources (product updates, patches, service packs, utilities, and validation tests).

6.7.3 Administrative Components (Procedures, Policies, and Training)

The administrative components are equally as important to manufacturing operation as the hardware and software components identified above. Some examples are as follows:

- Administrative procedures (operations, maintenance, design change control, access control, configuration management, system/data backup, reconfiguration, disaster/data recovery, and internal audit/assessment)
- Personnel access lists
- User and supporting personnel policies and procedures
- Training modules
- Audits/reviews
- Secure public information—control system information is protected from public access.

6.7.4 Methods and Responsibilities

After the change management plan elements are identified, it is time to establish the methods, responsibilities, and control steps that will be used to maintain operation, quality, safety, and security levels during the lifecycle phases of the Manufacturing and Control System. Because the scope and security boundary may extend well beyond the traditional software and hardware of the Manufacturing and Control System to other systems and applications, the change management plan may require a coordinated effort across organizational and physical boundaries. Methods used to enforce the change management plan may include, but are not limited to:

Copyright 2004 ISA. All rights reserved.

- Maintaining documentation of the security aspects of system requirements, vulnerability, system design, security boundary, benchmark/validation tests, procedures, and personnel access lists.

- Reviewing proposed changes to the Manufacturing and Control System and external systems for impact to the security boundary. Changes could involve design, upgrades, patches, new spare parts, and procedures.

- Identifying, controlling, and limiting access to sources of hardware, software, spare parts, patches, service packs used for system development, testing, and installation. This process may involve placing requirements on suppliers.

- Maintaining system recovery sources for rebuilding the existing system and previous versions.

- Performing verification/validation testing of security requirements after design changes, upgrades, maintenance, reconfiguration, and during system startup/recovery.

- Periodically assessing and testing the vulnerability of the security boundary commensurate with the level of security protection required.

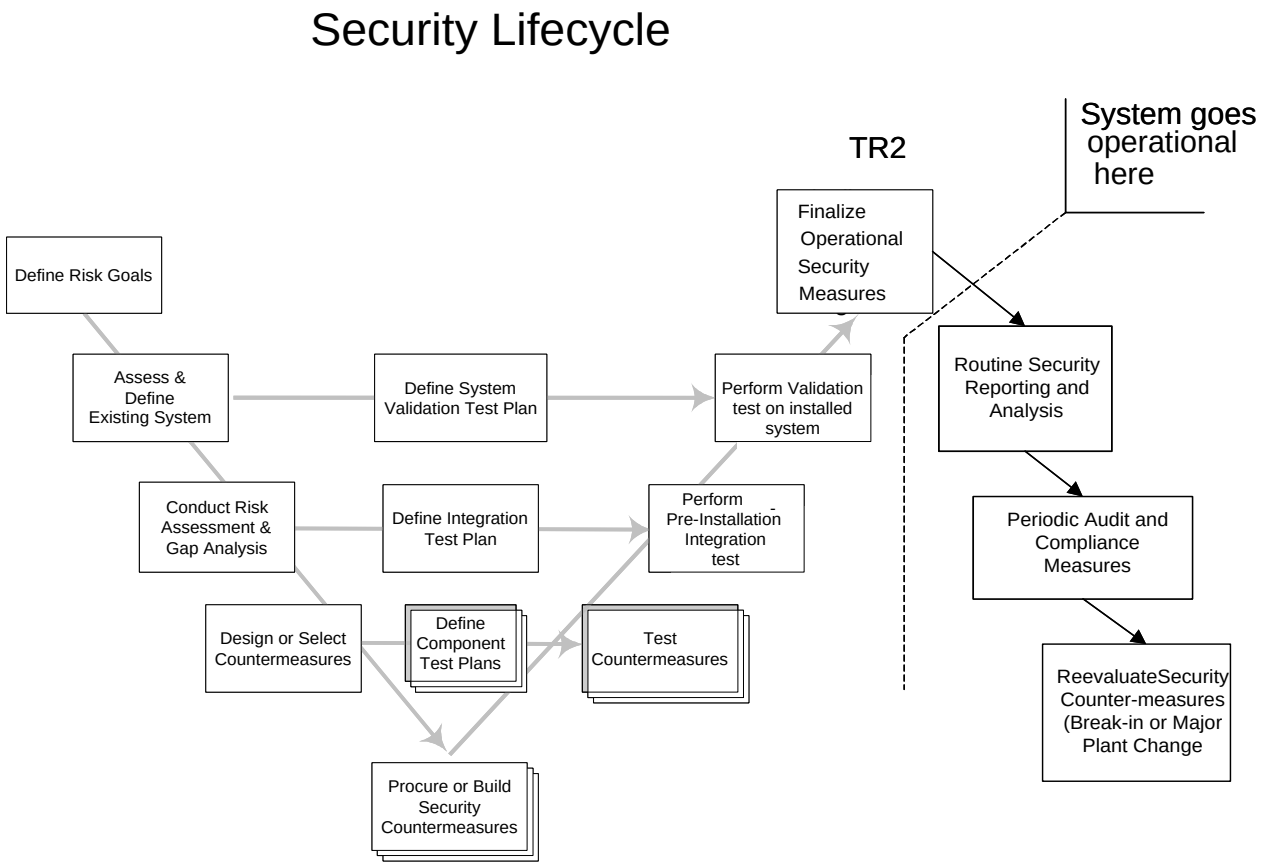
- Periodically or continuously monitoring user access, access lists, and failed/unauthorized access attempts.

- Periodically backing up vital data and operating parameters.

Copyright 2004 ISA. All rights reserved.

6.8 The Security Lifecycle

The above tasks can be accomplished by applying a systematic approach similar to that used for the management of safety-related systems described in the IEC 61508 standards, *Functional Safety of Electrical/Electronic/Programmable Electronic Safety-related Systems*, that describe a "safety lifecycle." A similar lifecycle was defined for use in ANSI/ISA-TR99.00.01-2004 ("TR1") and ANSI/ISA-TR99.00.02-2004 ("TR2") and is shown in the following diagram.



Copyright 2004 ISA. All rights reserved.

This model of the security lifecycle identifies specific steps that must be taken to assemble a complete security program. The following table provides a brief description of each step, as well as a reference to the section of this document that contains a more detailed description.

Description	Section
Define Risk Goals	7
Assess and Define Existing System	8
Conduct Risk Assessment and Gap Analysis	9
Design or Select Countermeasures	10
Procure or Build Countermeasures	11
Define Component Test Plans	12
Test Countermeasures	13
Define Integration Test Plan	14
Perform Pre-Installation Integration Test	15
Define System Validation Test Plan	16
Perform Validation Test of Installed System	17
Finalize Operational Security Measures	18
Routine Security Reporting and Analysis	19
Periodic Audit and Compliance Measures	20
Re-evaluate Security Countermeasures	21

6.9 Program Step Details

The remaining sections of this document describe each of the basic steps in the security lifecycle in more detail, including giving specific guidance and references.

Copyright 2004 ISA. All rights reserved.

7 Define Risk Goals

Risk goals define a company's tolerance level to risk. Defining the acceptable level of risk is key to beginning a security program. Once these goals have been articulated and agreed to, tactical implementation/operational policies can be developed to adequately address or mitigate the various risks identified during the risk assessment phase. The types of risks anticipated are identified and the appropriate level of response is determined, based on the nature of the system environment. Factors to consider include business impact, nature of materials being handled, regulatory controls, and cost constraints.

These goals must be clearly defined and approved at the appropriate management level because they determine the amount of effort that will be expended to address specific risks that arise. For example, the goal for addressing a risk to personal health and safety may be virtual elimination, while a similar goal for addressing the risk of release of non-toxic materials may be somewhat lower.

Types of risks may have been identified through a variety of means, ranging from corporate governance or external regulatory compliance to the application of a formal risk assessment methodology. Specific goals are identified to address them, and form the foundation of the security program.

Operational policies that define how security is to be applied to control systems should also be developed. These policies will address issues such as remote access, direct connections with corporate systems, and use of the Internet with control systems.

Annex A provides an example set of security policies and practices developed to support the security risk goals and overall security program for one company's Manufacturing and Control Systems environment. These examples are provided to illustrate the level of policy and practice decisions that need to be made to support meeting the risk goals.

8 Assess and Define Existing System

Once the basic program risk goals have been established, the next step is to conduct an assessment of the existing system. This step includes obtaining or developing a thorough system description.

8.1 Form Cross-Functional Team

The networks and hardware making up today's systems are fairly complicated and require a high degree of knowledge and sophistication. Setting up the security system and providing ongoing support can be no less daunting. The skill level required to perform tasks is not typically found within a single organization. Therefore, a cross-functional team can be quite valuable to accurately characterize the installed systems, design the best security architecture, and accomplish the task quickly. Plant personnel would normally be expected to lead this effort, including site manufacturing, process control, and IT. Others to be considered are the corporate engineering organization, corporate security organization, IT support organization, network engineers, and/or hardware vendors.

8.2 Pre-Risk Analysis Activities

8.2.1 Perform Screening Inventory to Identify and Characterize Manufacturing and Control Assets

Meet with process control and manufacturing personnel to identify the different process control systems used throughout the site. The focus should be on systems rather than just devices and should include

Copyright 2004 ISA. All rights reserved.

PLC, DCS, and instrument-based systems that use a central human interface monitoring device. Include manufacturing areas, as well as utility areas such as powerhouses and waste-treatment facilities.

Record the information in a standard format as you identify the process control systems. An example of a standard format is shown in the following and can be easily created in the form of a spreadsheet.

Copyright 2004 ISA. All rights reserved.

Manufacturing and Control Network Characterization

SBU _____
Business _____
Site _____
Operating Unit _____
Site IT Contact _____ Phone # _____
Site Process Control Contact _____ Phone # _____
Last Updated _____

PLEASE ANSWER THE FOLLOWING QUESTIONS :

_____ **Are manufacturing and control systems currently interfaced to site or corporate LANs?**
_____ **Are manufacturing and control systems remotely accessed from outside the manufacturing and control domain?**

Process Control Domain

_____ Total Number of IP addressable Nodes
_____ Number of IP addressable nodes to be accessed from outside process control domain
_____ Number of Concurrent Users inside Manufacturing and Control Domain
_____ Number of Concurrent Users inside Manufacturing and Control Domain requiring access to external resources
_____ Number of Total Users outside Manufacturing and Control Domain requiring access to Process Control Resources
_____ Number of Concurrent Users outside Manufacturing and Control Domain requiring access to Process Control Resources

IP Addressing (check all that apply)

_____ DHCP _____ Public addresses used (i.e. 49.x.x.x)
_____ Static _____ Private addresses used (192.168.x.x)

Control Platforms

_____ Number of Control Platforms
_____ Control Platform Type (PLC, DCS, PC)
Control Platform Manufacturer(s) _____ _____
Control Platform Model(s) _____ _____

Operator Consoles & HMI Devices

_____ Number of Operator Consoles
Operator Console Manufacturer(s) _____ _____
Operator Console Model(s) _____ _____
Operator Console Operating System(s) _____ _____

Application Nodes (check all that apply)

_____ PM&C Server
_____ SCADA
_____ OPC Server
_____ EWS
_____ PDC
_____ BDC
_____ Batch Server
_____ Other _____

Network Security Barriers In-Use

Type (Firewalls, routers, VLANS, etc.) _____

Anticipated Network Security Support (check all that apply)

_____ Site Resources
_____ External (CSC, 3rd party)

Site Network (answer Yes / No)

_____ Current site network topology diagrams available & up to date ?
_____ Are process control nodes on isolated LAN segment ?
_____ Site information security policy in place?
_____ Security office audit completed (if Yes, date completed _____)
_____ Does site use two-factor authentication ?
_____ Security office risk assessment completed (if Yes, date completed _____)

Remote Access Requirements (check all that apply)

_____ via site / corporate LAN
_____ via dial-up modem
_____ via internet
_____ via local dial-up modem directly tied to manufacturing and control node(s)

Local Egress Requirements (check all that apply)

_____ to site applications & resources (document management systems, quality systems, business systems)
_____ to corporate applications & resources (document management systems, quality systems, business systems)
_____ to internet sites

Copyright 2004 ISA. All rights reserved.

If the inventory is being performed as part of a corporate-wide security program, it may be beneficial to record the information in a searchable database.

Take care when identifying and inventorying process control systems and focus attention beyond the devices that perform direct control. The system or network may be more than the PLC or DCS. In an integrated manufacturing or production facility, the Manufacturing Control Network is comprised of devices that are directly used to manufacture, inspect, manage, and ship product and may include the following components:

- DCS controllers
- DCS operator consoles
- DCS configuration workstations
- Special DCS application nodes that perform functions such as alarm logging, historical logging, run models, or act as communication interfaces
- DCS domain controllers
- PLCs
- PLC human interface stations
- Shop floor (special purpose) computers
- Shop floor (special purpose) operator stations
- Process information management systems
- Process control modeling systems
- Expert systems
- Inspection systems
- Barcode scanning devices and systems
- Barcode labeling devices and systems
- Analyzers
- Network communication gateways
- Gauging systems
- Batch systems
- SOC (Standard Operating Condition) and SOP (Standard Operating Procedure) systems
- Document management systems
- Program development computers

Copyright 2004 ISA. All rights reserved.

- HVAC control systems
- Network protection devices (e.g., existing firewalls, IDS devices)

Consider including all computer processor-based networked devices that are critical to sustaining production. The objective of this inventory step is to discover devices to include in the risk analysis that make your process vulnerable to network-based attacks.

NOTE This time is not the decision point for deciding which devices should be isolated or separated from the LAN. Err on the side of including more devices rather than fewer. After you perform the Risk Analysis and have a better understanding of your overall vulnerabilities, you should decide if a firewall is truly necessary and where the various devices should be located.

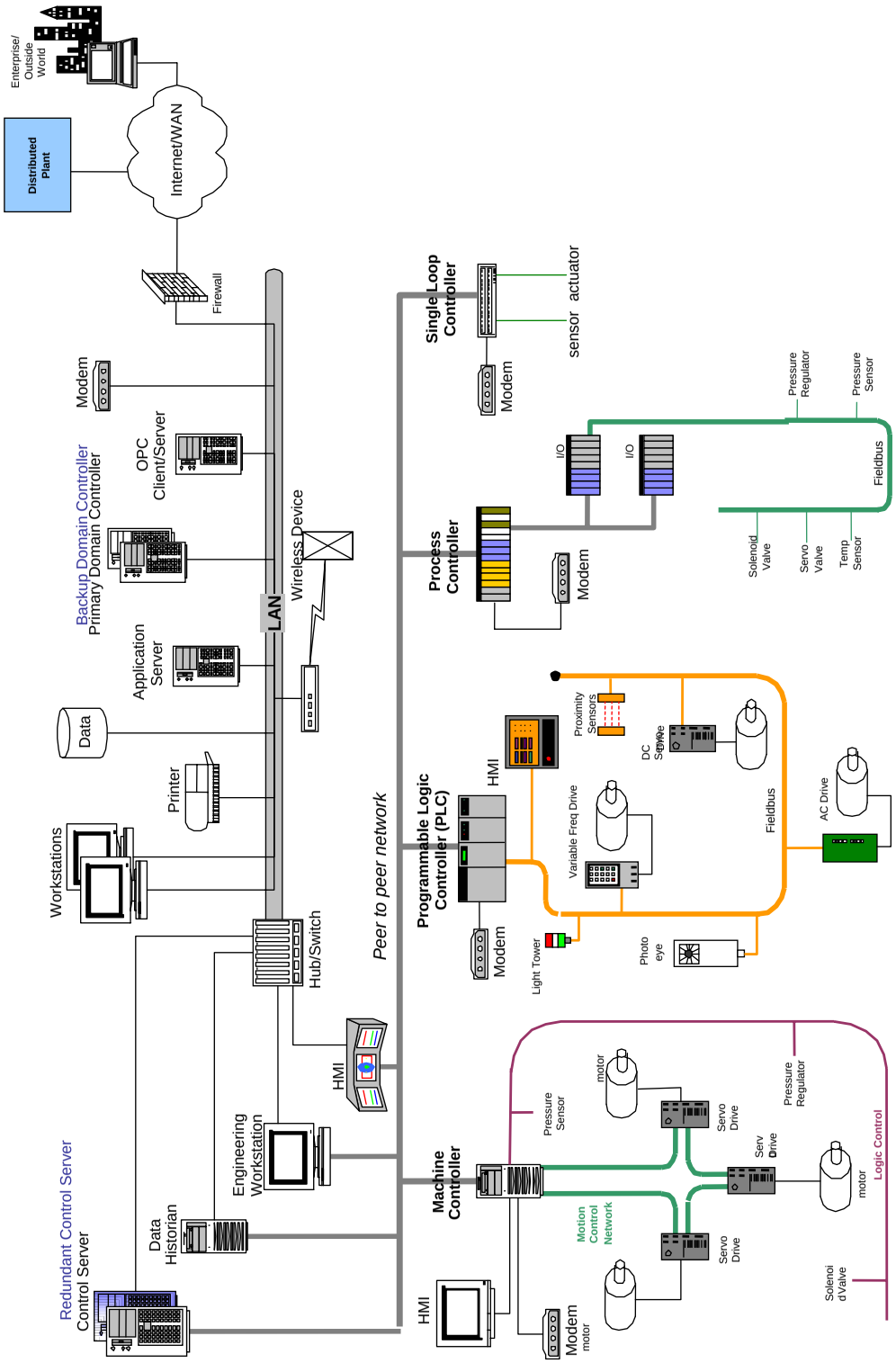
8.2.2 Develop Network Diagrams

Before conducting a risk assessment, it is important to have a clear understanding of the scope boundaries of the system to be assessed and set the boundaries for the systems to be analyzed. A good starting point is to develop a network diagram of the manufacturing computer system.

A network diagram is a graphical representation of the devices identified in the Manufacturing Control Network Inventory Assessment form discussed in the previous section. The diagram should attempt to capture the basic logical network architecture, such as connectivity approaches, combined with some of the physical network architecture basics like location of devices.

The diagram is a tool to help visualize the network and aid in performing the risk analysis. An example is shown below.

Copyright 2004 ISA. All rights reserved.



Copyright 2004 ISA. All rights reserved.

8.2.3 Automated Inventory Tools

There are several inventory tools that will work across networks to identify and document all hardware, systems, and software resident on the network. Conduct an assessment of how these tools work and what impact they might have on the connected control equipment before using any of them.

Tool evaluation may include testing on similar, non-production control system environments to ensure that they do not adversely impact production systems. While non-production systems may have no impact on production systems, they may send information that could (and has in the past) cause control systems failures or impairment. Impact could be due to the nature of the information and/or the system traffic and loading. While this impact may be acceptable in IT systems, it is not acceptable in Manufacturing and Control Systems.

8.3 Update the Screening Inventory

After developing the network diagram that defines the scope of your manufacturing computer system, go back and update the information in your Inventory Assessment form.

8.4 Make Preliminary Assessment of Overall Vulnerability

Plan to conduct a full risk analysis if you:

- determine that your process control system is presently connected to your site network or to outside networks (e.g., internet, modems). A risk analysis will help you better understand your vulnerabilities and the appropriate mitigation strategy to reduce risk.

- determine that your system is currently supported remotely.

- anticipate meeting either of the two criteria above in the near future. Perform the risk analysis before taking steps that place you into this high-vulnerability position.

Make a decision on where to devote your time for further risk analysis and mitigation based upon your analysis for system vulnerability and risk. Develop an initial prioritization to better channel your efforts.

9 Conduct Risk Assessment and Gap Analysis

9.1 Conduct Detailed Risk Analysis Vulnerability Assessment of the Prioritized Assets

The plan provides for system security assessments to determine vulnerabilities and weaknesses that need to be addressed. These assessments cover the assets identified and classified in the previous activity. They range from simple review of the systems design and configuration to a comprehensive assessment beginning with design and configuration reviews and including field walk downs to identify undocumented network connections, modems, wireless and other interfaces, and penetration testing to determine if existing security measures are adequate. Consideration needs to be given to all aspects of the Manufacturing and Control Systems being assessed, including unintended changes in system configuration brought about by maintenance, “temporary” supplier connections to the system for support, and even subtle changes in supplier design that could introduce new vulnerabilities through spare parts or upgrades, and should be considered and/or tested in the same manner as the original system components.

The plan needs to address systems that interface with the Manufacturing and Control System to ensure that they cannot be compromised by Manufacturing and Control System security or lack thereof.

Copyright 2004 ISA. All rights reserved.

Examples include development systems that provide on-line development capabilities and environmental and power systems whose compromise could create unacceptable risks.

In some cases, vulnerability may lie with the vendor. Vendor quality assurance and design control may require vulnerability assessment. This step is particularly important when ordering spare parts or upgrades; spare parts testing may be required.

Typical areas that may be vulnerable (and have been previously identified as weaknesses in certain systems) should be identified and examined, such as:

- Wireless access points, particularly IEEE 802.11b.
- Modem connections, particularly those that do not dial back and do not provide encryption.
- Use of remote access software (e.g., pcAnywhere®, Timbuktu®) programs that are typically used for access by experts within or outside the entity to support systems or operations. These applications can provide significant control and configuration access to an unauthorized individual.
- Use of remote windowing technologies such as X Windows®.
- Internet connections.
- Intranet connections.
- Telemetry networks.
- Any network connections to systems that are not a direct part of the Manufacturing or Control System.
- Any network connections used to couple parts of the SCADA or control system together that are not part of a physically secure, dedicated Manufacturing and Control System network. In other words, any network that extends beyond the boundary of a single physically secured perimeter, or across insecure areas, or is used for both manufacturing and control and other functions at the same time. Equipment included in network connections includes radio telemetry and outsourced services such as frame relay used to communicate between geographically separated areas.

9.1.1 Overview of the Process

There are several different methodologies that can be used to perform a security vulnerability assessment of your Manufacturing and Control Systems. Assessments can be divided into asset-based and threat-based methodologies, but should lead you to the same conclusion—identifying the information and particular devices that are vulnerable and must be addressed with appropriate risk-mitigation strategies.

The particular methodology included in this document falls into the asset-based category, which has been found to be fairly straightforward to implement and effective for a manufacturing environment. The examples in this section are based on using this methodology.

1) Identify your assets and record them in asset tables.

2) Examine asset vulnerabilities and assign a quantitative value to the vulnerability based on probability of an incident occurring and potential criticality of the result of the incident.

Copyright 2004 ISA. All rights reserved.

9.1.2 Identify the Assets

When you did the pre-risk analysis activities, you identified several process control devices in the "Manufacturing Control Network Inventory Assessment form" spreadsheet and network diagram. The next step is to begin to identify the assets to be protected. Because data and devices typically have different types of security issues, it is best to sort assets into two lists—**Data Assets** and **Network Application or Device Assets**.

9.1.2.1 Data Assets Examples

- Control algorithms
- Production schedules
- Process variables
- Set points
- Tuning data
- Account names, passwords, file names, host names
- Recipes
- Standard operating conditions
- Control configurations

Tabulate the data assets in a Data Asset Table (see table 1 for an example).

Table 1 — Data Asset Table Example

Data Assets					
The threat is the theft, corruption, falsification, or loss of the following data:	**Probability**	**Criticality**	**Remote Access**	**Local Egress**	**Comments**
Process variables					
Set points					
Tuning data					
Account names, passwords, file names, host names					
Control configurations/programs					

9.1.2.2 Application or Device Asset Examples

- Operator control stations

Copyright 2004 ISA. All rights reserved.

- Engineering workstation
- Email on console
- Internet access on console
- Control room printer
- Computer gateway
- Process measurement and control system
- Process controller
- Programmable field devices

Tabulate the application or device assets in the Application or Device Asset Table. An example is shown as table 2.

Table 2 —Application/Device Asset Table Example

Application/Device Assets					
The threat is the corruption, denial of service, or destruction of the following MCN applications/devices:	**Probability**	**Criticality**	**Remote Access**	**Local Egress**	**Comments**
E-mail on operator console					
Internet access on operator console					
Engineering configuration workstation					
Computer gateway					
Control room printer					

9.1.3 Identify and Rate the Threats

The next step is to classify the threat, which is a three-step process:

1) Identify the type of threat to which each asset is susceptible.

2) Assign a threat rating to each asset.

3) Determine how quickly a compromise needs to be detected and how long the threat can exist without mitigation.

The threat rating is based upon the probability of an incident happening and the criticality of the resulting action. These quantitative rating scales will be discussed in more detail later.

Classifying threats helps to identify vulnerabilities and encourages thought and awareness. Additionally, the classification is used for recommended mitigation steps. These steps are important because they provide guidance for implementing certain security measures and the justification for doing so.

Copyright 2004 ISA. All rights reserved.

Descriptions of the type of threats that may be encountered are shown below.

- **Information Disclosure**—Exposing information to individuals who are not authorized. Information disclosure threats include a user's ability to read a file to which he or she was not granted access and an intruder's ability to read data in transit between two computers.

- **Tampering with Data**—The malicious or accidental modification of data. Examples include making unauthorized changes to persistent data, such as information in a database, or altering data that flows between two computers over an open network, such as the Internet. Altered data could take the form of altered commands to the process controllers.

- **Spoofing Identity**—Illegally accessing and then using a user's authentication information, such as the user's username and password. Once inside a system, a hacker could take over and issue unwanted commands/messages to control devices.

- **Identity Repudiation**—Threats associated with users who deny performing an action when other parties have no way of proving otherwise. An example is a user performing an illegal operation in a system that can not trace the prohibited operations.

- **Denial of Service (DoS)**—Attacks that deny service to valid users by making a Web server temporarily unavailable or unusable. You must protect against certain types of DoS threats simply to improve system availability and reliability.

- **Elevation of Privilege**—Threats associated with unprivileged users gaining privileged access and thereby the ability to compromise or destroy an entire system. This threat includes situations where an attacker has effectively penetrated all system defenses and has become part of the trusted system itself—an extremely dangerous situation.

Once you understand the types of threats to which you could be subjected, the task is to examine the assets listed in the two network asset tables and attempt to rate the vulnerability of these assets to the types of threats. The quantitative rating scale below (table 3) will help you with this process.

Threats are classified by probability (likelihood) and criticality (impact or consequences).

Table 3 — Probability/Criticality Example

Probability	Criticality
A = Very likely	1 = Severe impact
B = Likely	2 = Major impact
C = Not likely	3 = Minor impact
D = Remote chance	4 = No impact

9.1.3.1 Probability Rating Scale

There are two factors to consider when determining threat probability: the source of the threat and the network segment exposure.

Copyright 2004 ISA. All rights reserved.

Likely sources of threats are from:

- **Outsiders**—Intruders from outside your network who come in from the Internet, dial-up lines, physical break-ins, or from partner (supplier or customer) networks linked to the corporate network. Outsiders are often called hackers, and they could possess some very detailed knowledge about the control system based upon experience with the same brand of control system at another installation. Outsiders may launch very directed attacks in the form of a break-in with specific action taken on a designated system device, such as corruption of a program or manipulation of a field control device. Another form of outsider attack is the non-directed use of malicious code like a virus or worm. The malicious code's impact on a system may be quite large and the outcome very unpredictable.

- **Insiders**—Legitimate users on your internal network who misuse privileges or impersonate higher-privileged users. In the Manufacturing and Control Systems environment, an insider can work for the manufacturing company, control system supplier, a consultant, or another company. Another threat from insiders comes from those who, through non-malicious behavior, cause accidental breaches of security policy either by mis-training or mis-typing. Insiders may launch the same sort of directed or non-directed attacks to systems described above.

The following classifications explain how hackers can be classified as to their threat potential.

- **A—very likely:** a moderately skilled hacker could easily pose a threat to an asset, such as stealing data or infecting a hard drive.

- **B—likely:** a moderately skilled hacker could pose the same threat with a great deal of effort.

- **C—not likely:** an expert hacker could only pose the threat with a great deal of effort.

- **D—remote chance:** an expert hacker would not be expected to pose a threat to your asset.

In the example methodology used in this section, some simplifying assumptions are made to reduce the complexity of the analysis and decrease the time to perform the analysis.

- Operators and support engineers who have in-depth knowledge of the manufacturing systems and the manufacturing process are trusted to safely operate the facility.

- The opportunity to launch a cyber attack from within the manufacturing area is less than that from outside the facility. Physical controls are in place to limit access to control devices and network connections from within the physical boundaries of the control area in the manufacturing operation.

- A disgruntled operator or support engineer intent on causing harm has the access and knowledge to physically hijack the process far easier than doing so by cyber means.

- The number of non-directed malicious code attacks by hackers exceeds the number of precisely directed terrorist hacker attacks.

- Overriding safety interlock systems, emergency shutdown systems, and auxiliary-independent backup devices are fully functional to guard against foreseen accidents.

Therefore, the assumption that the highest probability of a cyber threat comes from the outside simplifies the assessment by basing the risk on the network segments on which the data transgress or the location of the application or device.

Threat probabilities become more a function of the **method of access** and **the type of communications medium** than the skill of the hackers. If data travel over a less secure network segment like the Internet,

Copyright 2004 ISA. All rights reserved.

the threat probability is very likely because the data are potentially accessible to everyone in the world. Threat probability is also considered very likely if data are being sent from a wireless device that does not employ adequate security techniques. See table 4 for a threat probability example.

This simplification is not intended to say that hackers are not the real threat, but attention should be focused on understanding how much opportunity they have to invade your system. It is up to the user to determine whether the simplifying assumptions in this example make sense for his or her particular manufacturing facility. The assumptions most likely will be different for a nuclear weapons facility, a chemical facility, a pharmaceutical operation, or a packaging operation of commercial parts. The user may wish to employ the more classical approach to quantitatively assessing probability by examining the "difficulty of attack" and the "attractiveness of the target." There are many additional texts on the subject of risk assessment that can be consulted if the simplified approach included here does not address your site issues.

Table 4 — Threat Probability Example

Probability	**Criticality**
A = Very likely	1 = Severe impact
B = Likely	2 = Major impact
C = Not likely	3 = Minor impact
D = Remote chance	4 = No impact

Network Segments
Internet, Wireless, Direct Dial-in
Corporate Intranet, Two-factor, token-based authentication dial-in connection
Site LAN, integrated LAN
Isolated Manufacturing Control Network

Copyright 2004 ISA. All rights reserved.

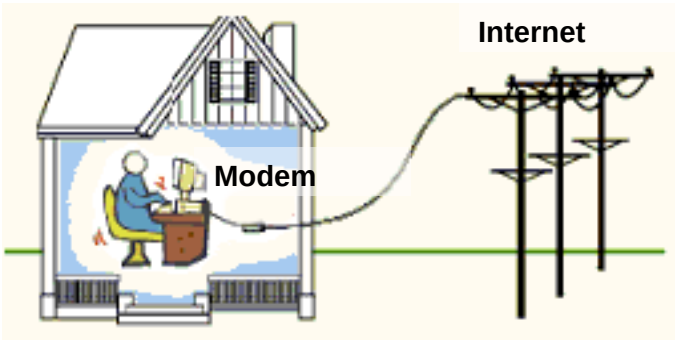
The diagram below further clarifies the network segment identified as Internet, Wireless, and Direct Dial-in.

These three network connection types all have similar security risk levels.

1. Internet connectivity involves all communications between the MCN and a client PC reaching the corporate Intranet through the internet.

2. Wireless connections employ radio frequency communication technology from the MCN to a PC located either within or outside the site boundary.

3. Direct dial-in is defined as dialing in to a modem or system that does not employ a secondary method of confirming the identity of the caller, such as token-based authentication.



Copyright 2004 ISA. All rights reserved.

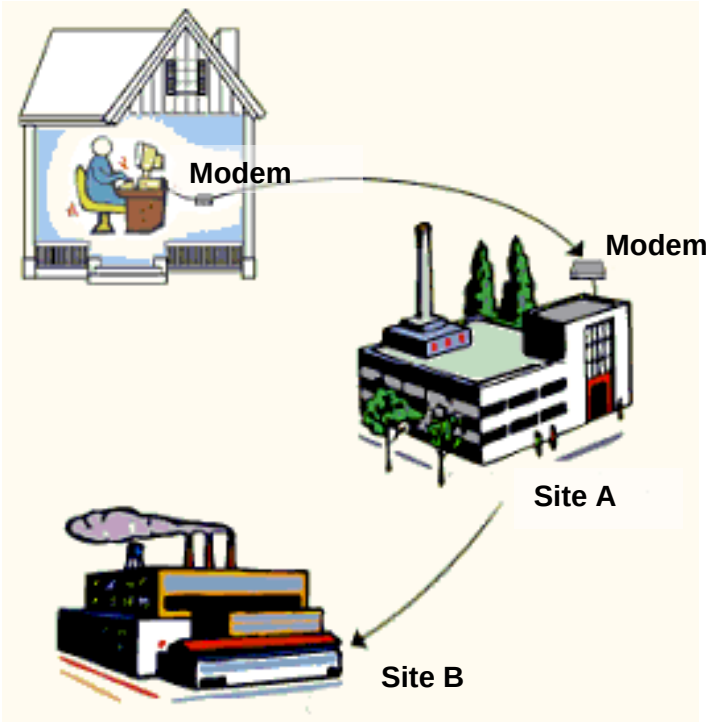
The diagram below further clarifies the network segment identified as corporate Intranet, two-factor token-based authentication dial-in.

Corporate Intranet and two-factor token-based authentication dial-in connections

These two network connection types have similar security risk levels.

1. Corporate Intranet connectivity addresses the connection of a client PC within the corporate Intranet, but outside the LAN.

2. Two-factor authentication dial-in connections employ token authentication or strong user authentication.



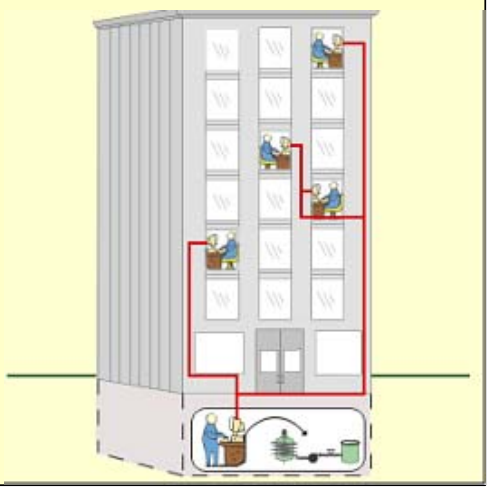
Copyright 2004 ISA. All rights reserved.

The diagram below further clarifies the network segment identified as Site LAN, Integrated Manufacturing Control Network.

Site Lan and Integrated MCN

This connection type describes PCs connected to the site LAN communicating to devices within the MCN.

Manufacturing and Office Site

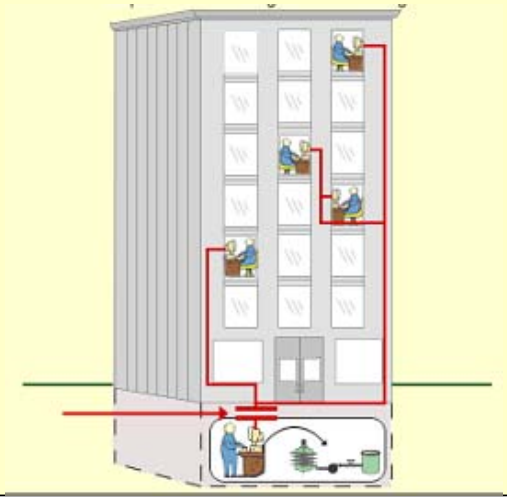


The diagram below further clarifies the network segment identified as Isolated Manufacturing Control Network.

Isolated MCN

The MCN has no connectivity to the site LAN or corporate Intranet. All PC clients are located directly on the MCN.

Manufacturing and Office Site



Using the network segment and media type to determine a probability rating is a simple assumption that is used in this example analysis methodology. More rigorous methods can be employed to determine probability. Any simplification used here must match with the overall risk goals and risk-mitigation policies and practices your company establishes for the Manufacturing and Control Systems environment.

Copyright 2004 ISA. All rights reserved.

9.1.3.2 Criticality Rating Scale

In addition to assessing the probability of threat to an asset, it is important to understand the criticality of an asset. Criticality is independent of the type or probability of a threat. The following supporting table presents several impact areas to examine to choose an appropriate criticality rating. These rating categories are very similar to those used for Process Safety Management.

If the threat can be classified using more than one category, select the criticality rating that is most severe. For example, if a certain threat would cause hours of interrupted production (impact/criticality=2) and cause a death (impact/criticality=1), the overall criticality of that threat is rated as 1.

Businesses and sites may have different interpretations of criticality. For example, some sites may define "hours" of interrupted production as a major impact instead of a minor impact. Tailor these definitions to suit your corporate risk goals and any site-specific values and environmental needs.

This process is intended to help people understand the security requirements of their site. Because the probability and criticality results are somewhat subjective, it is possible to shape definitions or classifications to produce a desired result. This action may produce results that represent a false sense of security. It is important to be realistic and objective about the definitions and classifications in order to get an accurate sense of security requirements. The user must select a rating scale and attributes that reflect his or her company’s tolerance for risk.

Copyright 2004 ISA. All rights reserved.

The graphic below depicts how the probability and criticality ratings can be quantitatively assessed based upon the descriptions in the supporting tables.

Probability	**Criticality**
A = Very Likely	1 = Severe Impact
B = Likely	2 = Major impact
C = Not Likely	3 = Minor impact
D = Remote Chance	4 = No impact

Network Segment	**Threat Probability**
Internet, Wireless, Direct Dial-in	A = Very Likely
Internet, Secure Dial-in	B = Likely
Integrated MCN	C = Not Likely
Isolated MCN	D = Remote Chance

Impact Category	**1 = Severe**	**2 = Major**	**3 = Minor**	**4 = None**
Injury	Loss of life or limb	Requires Hospitaliza -tion	Cuts, bruises requiring first aid	None
Financial loss	Millions	$100,000	$1,000	None
Environmental release	Permanent damage/ off-site damage	Lasting damage	Temporary damage	None
Interruption of Production	Week	Days	Minutes	None
Public Image	Permanent damage	Lasting blemish	Temporary tarnish	None

Copyright 2004 ISA. All rights reserved.

9.1.3.3 Rating the Probability and Criticality of Assets

Examine the assets listed in both the Data Asset and Device/Application Asset tables (see tables 5 and 6). Note whether this asset is accessed remotely (from outside the process control area) and whether this asset must be supplied to users who are located outside the manufacturing control area. Use the probability/location criteria discussed earlier and assign a probability rating to each asset. Record all ratings in the Asset tables.

Examine the assets listed in both the Data Asset and Application/Device Asset tables. Use the criticality rating guidance table discussed above and assign a criticality rating to each asset. Record all ratings in the Asset tables.

Table 5—Data Asset Rating Example

Data Assets					
The threat is the theft, corruption, falsification, or loss of the following data:	**Probability**	**Criticality**	**Remote Access**	**Local Egress**	**Comments**
Process variables	B	1	Yes	Yes	includes regulatory data
Set points	B	1	Yes	Yes	
Tuning data	D	1	Yes	No	loop info, etc.
Account names, passwords, file names, host names	B	2	Yes	No	
Control configurations/programs	C	1	Yes	Yes	document control?

Table 6—Application/Device Asset Rating Example

Application/Device Assets					
The threat is the corruption, denial of service, or destruction of the following MCN applications/devices:	**Probability**	**Criticality**	**Remote Access**	**Local Egress**	**Comments**
E-mail on operator console	A	1	Yes	Yes	
Internet access on operator console	A	1	Yes	Yes	
Engineering configuration workstation	C	1	Yes	Yes	
Computer gateway	B	1	No	Yes	need to better understand capability of interface
Control room printer	B	4	Yes	No	

9.2 Prioritize Systems for Implementation Phase of Risk Mitigation Plan

Once the vulnerabilities have been identified, it is important to assess them in terms of relative priority because it is unlikely that they all can be addressed immediately.

Copyright 2004 ISA. All rights reserved.

10 Design or Select Countermeasures

With a defined and prioritized set of vulnerabilities, you can begin to identify specific countermeasures for those that are most immediate.

10.1 Implement Risk Mitigation Strategies Based upon Detected Vulnerabilities

10.1.1 Risk Mitigation Strategies

There are a number of steps you can take to reduce the cybersecurity risk and vulnerability of your Manufacturing and Control System. The most common strategy involves separating the business LAN from the Manufacturing Control Network. While this is not the only strategy to consider, it does form the foundation for most strategies. The Mitigation Strategy Matrix Tables must be developed to support the company's risk goals and risk mitigation policy. The tables provide guidance for reducing the level of risk associated with your Manufacturing Control Network. Based upon the threat classification ratings, the tables recommend when to employ a firewall or other security technology as a way to reduce risk to your process.

Examine the ratings in the Device/Application Asset table (see table 7). Determine the highest threat rating for an application/device asset (e.g., A1). Locate A1 in the Mitigation Strategy Matrix table (table 8) for Device/Application Assets and determine the security level required for your process control network (i.e., firewall required).

Table 7— Manufacturing and Control Network Application/Device Asset Rating Example

Manufacturing and Control Network Application/Device Assets					
The threat is the corruption, denial of service, or destruction of the following MCN applications/devices:	**Probability**	**Criticality**	**Remote Access**	**Local Egress**	**Comments**
E-mail on operator console	A	1	Yes	Yes	
Internet access on operator console	A	1	Yes	Yes	
Engineering configuration workstation	C	1	Yes	Yes	
Computer gateway	B	1	No	Yes	Need to better understand capability of interface
Control room printer	B	4	Yes	No	

Copyright 2004 ISA. All rights reserved.

Table 8—Mitigation Strategy Matrix Table for Application/Device Assets

Probability	Manufacturing and Control Network Application and Device Assets	Criticality			
		1 Severe	2 Major	3 Minor	4 None
	A – Very Likely	Firewall required	Firewall required	Firewall required	
	B – Likely	Firewall required	Firewall required	Firewall recommended	
	C – Not Likely	Firewall required	Firewall required	Firewall recommended	
	D – Remote Chance	Firewall recommended			

In a similar manner, review the threat ratings in the Data Asset table (see table 9) and locate these values in the Mitigation Strategy Matrix table for Data Assets (table 10). This information provides guidance on how to protect this data asset. During implementation design, you may choose to adopt different mitigation strategies for different kinds of data assets. In the example below, the control configuration programs have a rating of C3. The matrix table suggests that mitigation is not recommended to protect this data asset.

Table 9—Data Asset Rating Example

Data Assets					
The threat is the theft, corruption, falsification, or loss of the following data:	**Probability**	**Criticality**	**Remote Access**	**Local Egress**	**Comments**
Process variables	B	1	Yes	Yes	Includes regulatory data
Set points	B	1	Yes	Yes	
Tuning data	D	1	Yes	No	Loop info, etc.
Account names, passwords, file names, host names	B	1	Yes	No	
Control configurations/programs	C	3	Yes	Yes	Document control?

Copyright 2004 ISA. All rights reserved.

Table 10—Mitigation Strategy Matrix Table for Data Assets

Probability	Data Assets	Criticality			
		1 Severe	2 Major	3 Minor	4 None
	A – Very Likely	Mitigation required	Mitigation required	Mitigation required (to Intranet perimeter)	Mitigation required (to Intranet perimeter)
	B – Likely	Mitigation required	Mitigation required		
	C – Not Likely	Mitigation required			
	D – Remote Chance				

10.1.2 Mitigation Design

If you decide to install a firewall to separate your LAN from the Manufacturing Control Network, it may be helpful to develop a chart that lists all assets categorized by type (device/application or data), network segment, and logical location relative to a firewall barrier. An example of this type of matrix is shown in table 11. Remember, the assets in your system will probably be different.

As you develop this logical design, ask yourself the following questions:

- Is there value derived from an asset's connection to the network, or should the asset simply be removed or isolated?

- Can assets be moved or network connections rerouted to minimize the number of firewalls required?

- If a sub-unit of a larger site is being assessed, can it be protected more efficiently in combination with other parts of the site?

- What alternate steps should be taken to reduce the vulnerability of this asset? For example, frequent backups to reduce potential for data loss, employing RAID (redundant array of independent disks) and disk image cloning and management technologies to reduce the potential for data loss, redundant hot devices to reduce downtime potential, in-place cold duplicate devices for manual switchover to reduce downtime potential, and the like.

Transform this logical network layout to the actual physical network design. Produce Manufacturing Control Network design documents showing all nodes on the process control network, all applications that interact with process control systems, firewall location, pertinent site architecture, and routing infrastructure.

Copyright 2004 ISA. All rights reserved.

Table 11—Application and Data Asset Topology Example

	Data		Applications and Devices
Remote dial-in Remote access software program Application client	Internet		Remote access software or similar client Historian client Maintenance client Plant optimization client
	Corporate WAN	Production data Quality data	Network applications (LIMS, SAP) Remote access software or similar client Historian client
	Site LAN	Production schedules SOCs AOPs Historical data	File server Application server (read only) Network printer Historian client E-mail Internet access Remote access software or similar client
	Firewall		
	Manufacturing Control Network	Process variables Set points Control configuration/programs Historical data Work station account names and passwords	Application nodes (future) Operator control station Engineering workstation Computer gateway DCS PLC CEMs Remote access server FTIR Analyzer Remote access software server Browser on HMI MS Office on HMI PLC workstation Printing on HMI Printing on DCS

Copyright 2004 ISA. All rights reserved.

10.2 Address Vulnerabilities

The ISA-SP99 committee recognizes this topic as important and will address it in a future revision of this Technical Report.

10.2.1 Physical Security

The ISA-SP99 committee recognizes this topic as important and will address it in a future revision of this Technical Report.

10.2.2 Common Problems and Solutions

The ISA-SP99 committee recognizes this topic as important and will address it in a future revision of this Technical Report.

10.2.3 Address Common Problems Immediately

- Most problems can be addressed through application of policy and procedures in the “systems management” area.

- Establish a secure default state instead of an “open” default state (isolation, passwords, permissions). Keep in mind that using a secure default setting could impact system operation.

- Establish connections only when needed
  - Use existing approaches to make connections secure
  - Add special features where needed
- Limit access and functionality
  - Configure and provide ONLY what is needed to perform the job
- Use appropriate access controls
  - Use passwords where practical
- Encrypt where appropriate
  - Avoid where time-critical requirements do not allow or where it is not necessary
  - Consider streaming encryption or other approaches for time-critical requirements

10.2.4 Additional Activities

Address additional areas where the impact on system functions was confirmed to be acceptable:

- Configure manufacturing and control network infrastructure for electronic security
- Configure HMI and other workstations, servers, and network computers for electronic security

Copyright 2004 ISA. All rights reserved.

- Configure DCS and PLC interfaces and controllers and Intelligent Electronic Devices (IEDs) so that they are secure, but are still practical and capable of being used
- Install and configure virus protection software and make sure it is kept current
- Provide intrusion detection
- Complete all vulnerability scans (phone, Intranet, Internet)
- Wireless—don't use or do so with recognition that security is less robust. Mitigating controls should be put in place to contain the risk.
- Firewalls
  - Configuration scans and control

10.3 Formalize Change Management Plan for the System

The plan should incorporate strong change evaluation and control. Many of the procedural and configuration details discussed above are simple to implement, and will provide increased security. However, they can have unexpected, undesired, and profound consequences on the systems being managed, if not well thought out, carefully planned, and rigorously tested before application. The plan should provide such controls to preclude undesired impacts from security "enhancements."

11 Procure or Build Countermeasures

11.1 Translate Requirements from Design Phase to Specification or Complete Construction

One resource that will be available in the future for a rigorous definition of the security performance requirements of a component or system is being generated by the U.S. NIST-sponsored Process Control Security Requirements Forum (PCSRF). This government forum is developing guidelines for using Protection Profiles as a means of rigorously defining security functions/ performance requirements in a way that removes ambiguity. When developed, the Protection Profiles may be used by a purchaser as part of the purchasing specifications, which would also include any additional security functionality, the assurance and testing requirements, and the non-security (operational) requirements of the components being purchased.

A description of the nature and goals of the PCSRF forum is given in Section 23.

12 Define Component Test Plans

12.1 Decisions to Make When Planning a Test Program

Ultimately, an installed system needs to meet both the operational objectives and the security goals. A good component, integration, and system validation test program needs to include security performance testing, as well as operational (non-security performance) testing of the final configured system. The security functions are just another aspect of the overall performance capabilities the system must provide. The base security capabilities of the component making up the system reside at a low enough level in the component's architecture that they can be readily separated from operational functions and be tested independently to achieve reasonable assurance of acceptable security performance. The discussion that follows focuses on both the security capabilities and non-security (operational) performance of the components.

Copyright 2004 ISA. All rights reserved.

There are many aspects of a test program to consider, ideally before the final purchase order for equipment is signed. Decisions include:

- Degree of Testing and Assurance—What sort of assurance does the buyer want to specify (and pay for) so that the purchased security components meet the security and non-security functional requirements and specifications? Does the vendor (or the customer) have the laboratory or test bed facilities to perform this testing, or is an outside/independent lab necessary? In this document, we may classify the degree of assurance specified or required in two categories: low assurance and high assurance.

- Security component type under test—Is the security component (countermeasure) hardware, software, or does it contain both?

- What sort of security and non-security (operational) performance should be included in the test program? The following chart lists some typical security and non-security performance issues that might be tested.

Security Performance	•Through operational lifecycle (secure state maintained throughout startup, normal operation, shutdown, standby, maintenance)? •Authentication capability and integrity •Audit trail and audit trail integrity •Integrity violation notification
Non-security (operational) performance	•Environnemental conditions (temperature, humidity, vibration, EMI, etc.) •Usability •Safety performance •Performance under stress •Reliability •Maintainability

- Type of testing appropriate versus assurance level:

  - For a **low assurance level**—the type of testing appropriate is generally “black box” testing, which means that you treat the component under test as a complete entity, testing its external security and non-security properties only. No effort is made to find out what is “under the hood,” (go back and see how the product was developed, engineered and manufactured). The only item of concern during the test is how this item will perform its security and non-security functions when installed in the system.

  - For a **high assurance level** test program, the belief is that the proper security, and perhaps also the non-security performance of the component, can only be assured by examining the component’s “pedigree” (research the process by which the security component under evaluation was designed and manufactured). This process is called “white box” testing, and is more involved, time-consuming, and costly, but may be justified when security/non-security performance must be verified to be at a high level. The belief is that only through engineering in the security, using inspection, and testing at every step of the manufacturing process can you be absolutely certain that the security component will perform as required in a security critical application.

Copyright 2004 ISA. All rights reserved.

It is possible that a security component has very critical non-security (operational) functions. For instance, if a component has safety functions as well as security, it is conceivable that the safety functions are more critical and need more testing and assurance than the security functions.

In the Component, Integration, and System Validation testing sections that follow, complete testing might involve separate or combined hardware and software testing.

One important factor to consider when formulating test plans is the necessity for a non-production facility, or test bed, on which to run acceptance tests on individual components and combine them together, if possible, for an integration test. Development and test activities can cause serious problems (e.g., unwanted modification of files or system environment or system failure). Carefully consider the level of separation necessary between operational, test, and development environments in order to prevent operational problems. A similar separation should also be implemented between development and test functions.

Separating the development, test, and operational facilities is recommended to reduce the risk of accidental change or unauthorized access to operational software and business data and prevent inappropriate developer access. If the development and test staff have access to the operational system and its information, they may be able to introduce unauthorized and untested code or alter operational data. On some systems, this capability could be misused to introduce untested or malicious code. Developers and testers also pose a threat to the confidentiality of operational information. Development and testing activities may cause unintended changes to software and information if they share the same computing environment.

Some component testing may be performed offsite, by the vendor of the security control equipment, or by a third party. Rarely will the outside parties have the exact configuration of the control system that exists in the plant. A simplified or replica system in a development or laboratory system on or near the site of a production system is best suited for the component and integration test phases. The component and integration test plans would then be designed around this test bed facility.

Security control components should only be installed in a production system if individual components successfully pass individual and, if possible, integration tests. A full-scale validation/acceptance test should take place after components are installed and commissioned.

It is important to emphasize that “security countermeasures” may involve people operating through policies and procedures, as well as manual checks of security. A countermeasure, for instance, may consist of a control engineer installing a security patch issued for hardware or software. The test plan might go through the sequence of a “dry run” of the patch installation, noting other factors it influences.

Unlike traditional system testing, the mission of security testing is to corrupt either component or integrated features of a system in an attempt to meet test plan goals.

12.2 Sufficient Testing

Ideally, a system would be tested under all possible states to ensure that every security contingency is met, or at least so that the residual risk differential becomes known. The difficulty with “complete” system testing is that while theoretically possible, it is unobtainable for most specifications given time and resource constraints. Therefore, the challenge for the security tester is to perform “sufficient testing.”

What may be defined as sufficient testing is made easier by referring to the gap analysis performed in stage 3 of the Security Lifecycle (see section 9, Conduct Risk Assessment and Gap Analysis). Gap analysis provides a method to prioritize threats to system segments. However, because all fault class goals are not known, 100% security can never be assured.

Copyright 2004 ISA. All rights reserved.

Testing may include a variety of approaches such as boundary value analysis, stress testing, regression testing, root cause analysis, and perhaps chain-of-events modeling, hazards analysis and fault trees adapted to security. A variety of testing tools such as test scripts, databases of variables, baseline configuration with an assumed start state, metrics, and calibration tools, is available. Commercial and freeware tools are available that are pre-configured to perform diagnostic routines and simulate gateways and connected devices.

12.3 Component Test Plans

Component testing is testing performed by the vendor, the user's plant, or an outside lab to assure all parties that the purchased security components will meet the purchase specifications and will demonstrate the required security performance.

Some component testing may be performed offsite, by the security control equipment vendor, or by a third party. Rarely will the outside parties have the exact configuration of the control system that exists in the plant. A simplified or replica system in a development or laboratory system on or near the site of a production system is best suited for the component and integration test phases. The component and integration test plans would then be designed around this test bed facility.

As mentioned above, the security component may be software, hardware, or a combination of the two.

The following example shows a component test for the installation of a software guard on an Intelligent Electronic Device (IED). The process for performing a component test is:

1. Prepare the Component Test Plan
    a. Include Purpose, Scope, and Time Constraints
2. Prepare and Verify Test Procedures
    a. Define Tests to:
        i. Include all component segments, inputs, & outputs; use simulation stump for connecting interface components.
        ii. Use accepted security testing techniques such as Hazards Analysis, Fault Trees, Chain of Events, or Root Cause Analysis
    b. Define and prepare adequate Test Cases to:
        i. Include all possible decision outcomes.
        ii. Test *data*, *component logic*, *timing*, and *environmental* constraints;
            1. under normal operating conditions,
            2. on component boundaries, and
            3. outside system boundaries within a predetermined confidence range.
        iii. Include hypothesized error conditions.

13 Test Countermeasures

Perform the test plan on each component per the test plan defined above. Create and review a test report that includes the following items:

- Lists of actual hardware, software, processes, and persons included
- A summary of tests performed, testing methods, and tools
- The date and timing of activity
- Versions of relevant documents

Copyright 2004 ISA. All rights reserved.

- Summarization of the expected results
- Identification of discrepancies, if any, between expected and test results
- A plan for corrective action if necessary

14 Define Integration Test Plan

In some instances, it is possible to perform a non-production integration test to see how security countermeasure components will work together. For example, security countermeasures that consist of discrete hardware/software may be connected via a lab test bed network. In other cases, this integration may not be possible. The integration test plan should take advantage of any test bed scheme that can be configured to test combinations of operating conditions that may be present in the production system.

Integration testing and assurance involve examining and testing several security components, perhaps from different vendors, that are temporarily connected together on a workbench or in an auxiliary test bed in an effort to see if the security components will work together correctly before being placed in the Manufacturing and Control System environment.

The following example shows the connection of an IED, with a recently installed and tested guard, to a local area network:

1. Prepare Integration Test Plan
    a. Include Purpose, Scope, Time Constraints
2. Prepare and Verify Test Procedures
    a. Define Tests
        i. To be performed with previous component tested units.
        ii. Which include all resources used by the integrated *subsystem.*
3. Define and prepare adequate Test Cases to:
    a. include all functional and performance attributes under all modes of operation
    b. attempt to create new faults in the subsystem interfaces, and subsystem components modules using hardware, software and data errors
    c. subvert security functionality
    d. stress timing, failsafe defaults, error conditions, and error recovery.

15 Perform Pre-Installation Integration Test

Perform pre-installation integration testing of all security countermeasure components, as many as possible in a test-bed hookup, as previously described.

16 Define System Validation Test Plan

System Validation testing is the testing performed on the entire Manufacturing and Control System after the security components have been inserted, configured, and made operational and is an integral part of the security lifecycle. The objective of validation testing is to ensure that the new security countermeasures, as procured and installed, meet the following criteria:

- They are installed correctly.
- They are reconfigured correctly.

Copyright 2004 ISA. All rights reserved.

- They meet the completed security controls specification.

- Most important, testing fulfilled the user's documented security requirements. Additionally, the completed system should meet the original intent of the user with respect to security.

The following example shows testing from the operating SCADA console of the measurement devices on an IED containing a recently installed and tested guard.

1. Prepare Validation Test Plan
    a. Purpose, Scope, Time Constraints
2. Prepare and Verify Test Procedures
    a. Define Tests
        i. To include entire system states inclusive of HMI
    b. Define and prepare adequate Test Cases to:
        i. Include segments tested under integration test
        ii. use *dynamic simulation* of input signals, to demonstrate the *subsystem* capabilities under steady state conditions, changing input conditions, abnormal input conditions, and accident conditions. The test cases shall cover all modes of operation.
        iii. exercise the capabilities needed by *users*

17 Perform Validation Test on Installed System

System validation testing has a dual purpose to:

- Demonstrate through appropriate verification techniques, verification procedures, and procedure refinements (as needed) that the management, operational, and technical security controls for the Manufacturing and Control System are implemented correctly and are effective in their application.

- Prepare the final Manufacturing and Control System test report(s) based on the results of the activities carried out during the testing phase.

Perform the system validation test after installing and commissioning security controls in the system and after proper configuration.

Prepare a report containing the same elements as in section 12, Define Component Test Plans.

18 Finalize Operational Security Measures

This process includes using test results and conducting a final review to confirm that previously developed procedures and standards are achievable, and then implementing the procedures.

18.1 Establish Operational Security Baseline

Use the test results and final setup from the validation testing of security countermeasures installed in the system to define the production operating parameters for the installed security controls.

Copyright 2004 ISA. All rights reserved.

18.2 Finalize Operational Security Policy

Compare the previously prepared operational security policy set (consisting of high-level policy, standards, and procedures) with the results of the validation testing and the operational security baseline. If the previously prepared policy set is in agreement, this policy set may be then issued and enforced.

18.3 Establish Management of Change (MOC) Program

A management of change (MOC) program, as used in a safety context, reviews any future process or control and instrumentation changes with a wide variety of stakeholders to see if the proposed change will cause unforeseen and negative safety side effects.

A management of change security program is similar, except that prospective changes are reviewed for unforeseen and negative effects of process or control and instrumentation changes on the security of the system.

It is important to note that when implementing a security management of change program, changes to control systems must be examined for their possible effects on safety, and vice versa. The security management of change program should be integrated into the Process Safety Management program at the site so that a holistic assessment is made of any changes to the Manufacturing and Control System. The management of change program should be employed for any manufacturing process change and Manufacturing and Control System change as a result of changes in system hardware and software.

18.4 Establish Periodic Audit Plan

After the security controls validation step, an audit plan should be implemented to perform the following audits:

- Validate that the original security controls present during the initial system validation are still installed and operating correctly in the production system.

- For all installed security controls performing their intended functions, verify that the production system is free from security compromises and provide information on the nature and extent of compromises, should they occur.

- Verify that the management of change program is being rigorously followed with an audit trail of reviews and approvals for all changes.

- Establish a set frequency of periodic audits and re-audits

18.5 Establish Audit Metrics

Results from each periodic audit should be expressed in the form of performance against a set of predefined and appropriate metrics to display security performance and security trends.

18.6 Establish Audit Metrics Reporting Procedure

Security performance metrics should be sent to the appropriate stakeholders, along with a view of security performance trends.

Copyright 2004 ISA. All rights reserved.

18.7 Establish Compliance Requirements

Compliance criteria are finalized upon validation testing/security baseline establishment. Stakeholders at the appropriate level should receive the audit results, weigh them against compliance criteria, and either accept the results as confirming the security performance is being maintained, or start a corrective action cycle to remedy the security deficiency.

18.8 Establish Corrective Action Procedures

The appropriate stakeholder should specify what corrective action is required to remedy the out-of-compliance situation.

18.9 Disaster Recovery

One noteworthy element of the management of change program is the disaster recovery plan for the components and system. The disaster recovery plan must address the detailed process to restore both the operational and security aspects of the manufacturing and control system. The plan's backup and recovery strategies and procedures must be documented and tested on a periodic basis to ensure the ability to recover to a prior functional and secure state.

18.10 Monitoring and Logging

All available system logs should be examined and monitored on both a periodic basis and when abnormal activities may indicate problems.

18.11 Intrusion Detection

The plan should provide for intrusion detection at an appropriate level for the system, which can range from detecting hardware and physical intrusions to detecting unauthorized remote access or activities. Intrusion detection may incorporate process models, cross correlation between redundant or diverse data, and other techniques to assess the validity of the data. The intrusion detection system should also provide appropriate notification and/or response to intrusions detected.

18.12 Incident Response

The plan provides for responding to security incidents through the following activities:

18.12.1 Detection and Response

Assign event and intrusion detection (see section18.11) notification and alerts so that personnel respond to, terminate, and resolve accidental or malicious incidents.

18.12.2 Reporting

Document events or incidents and report them to appropriate management and any reporting system to which the entity belongs.

18.12.3 Industry Event Monitoring

Monitor applicable industry groups and/or alert notification organizations. The plan provides for appropriate actions based on event notifications. Potential sources of alerts include:

Copyright 2004 ISA. All rights reserved.

- supplier user groups or security event notification bodies
- event databases (such as that of the British Columbia Institute of Technology)
- Industry Information Sharing and Analysis Centers (ISACs)
- CERT (U.S. Computer Emergency Readiness Team)

18.13 Contingency Plans

The plan provides contingency plans covering the full range of failures or problems that could be caused by failures in the Manufacturing and Control System electronic security program. Contingency plans should include procedures for restoring systems from known good backups, separating from all non-essential interfaces and connections that could permit electronic security intrusions, and alternatives to achieve necessary interfaces and coordination. Contingency plans should be periodically tested to ensure that they continue to meet their objectives.

18.14 Normal Support

Normal support includes all the day-to-day activities in the organization to maintain security control (e.g., implementing patches, virus updates, reports, configuration changes, password and personnel maintenance).

18.14.1 Reports

The plan provides for periodic reports to management detailing operation of the plan, along with recommended changes to the program so that it more effectively meets objectives. Reports could include:

- Plan and Program Status—An overview of the plan, how effective it has been, audit results, and plans for improvement.
- Vulnerabilities Identified and Addressed—A list of all vulnerabilities identified and a recommendation on how they will be addressed.
- Intrusions Detected and Addressed—A list of all intrusions that were detected and a recommendation on how they will be addressed.
- Recommendations Based on Experience to Date—A list of recommendations for improving the plan and program so that it addresses all vulnerabilities detected and better meets the objectives of the security program.
- Next Activities and Report Schedule—A detailed list of activities to be performed to conform to the plan or address vulnerabilities identified in previous audits and a schedule for future reports.

18.15 Formalize Audit Plan for the System

The plan provides guidance for auditing the plan and its implementation to ensure that it is effective at meeting its objectives. Such audits would normally include the following items:

Copyright 2004 ISA. All rights reserved.

18.15.1 Policies

Review policies, standards, and procedures to confirm that they have been established and provide appropriate consideration of those items listed here, as well as other items applicable to the entity in question.

18.15.2 Inventory

Verify that an inventory of information on potentially vulnerable systems has been developed and is up-to-date.

18.15.3 Risk Assessment

Perform a risk assessment to identify all systems that require vulnerability assessments.

18.15.4 Vulnerability Assessments

Verify that all systems identified in the risk assessment have been assessed to determine vulnerability. Make sure that typical problem areas have been assessed and addressed as necessary.

18.15.5 Vulnerabilities Addressed

Verify that all vulnerabilities identified have been addressed in an appropriate manner and system functionality has been maintained.

18.16 Implement

After the program details are completed and planned and personnel are trained, the security program is implemented.

19 Routine Security Reporting and Analysis

The ISA-SP99 committee recognizes this topic as important and will address it in a future revision of this Technical Report.

20 Periodic Audit and Compliance Measures

The ISA-SP99 committee recognizes this topic as important and will address it in a future revision of this Technical Report.

21 Reevaluate Security Countermeasures

The ISA-SP99 committee recognizes this topic as important and will address it in a future revision of this Technical Report.

22 Work with Suppliers and Consultants

When developing and applying a security plan, it is common practice to adopt a largely internal focus. This approach overlooks the significant benefits that can be gained by collaborating with various external

Copyright 2004 ISA. All rights reserved.

parties and groups. Sharing experiences with others increases the general body of knowledge on control systems security, which improves the quality of this information for everyone.

Most of the major control system suppliers offer some support in the security area; some offer significant support. Their knowledge and the services offered are increasing with time. Contact your suppliers and solicit advice relative to how their systems can be secured, the support they provide, and recommendations for making changes to your existing system. Some suppliers also offer user group experience and other benefits to identify and address vulnerabilities.

Hardware and software system integrators and users groups are a key source for providing support on conducting careful analysis and testing necessary before making hardware and/or software changes or upgrades intended to enhance security. There are also several consultants who offer significant expertise in the areas of plan development, assessments and risk analyses, and vulnerability reduction.

Each source has potential benefits and opportunities.

22.1 System Suppliers

System suppliers are an obvious source for detailed technical information on the features and functions of their products. This information typically takes the form of detailed reference documents and user manuals, and may be the subject of formal training courses. However, these manuals and courses may not adequately address the question of best practices in how to apply or configure the products for security considerations.

Often this information is best obtained through collaboration with the projects or services organization of the supplier company. Executing a project in partnership with members of this group is an excellent way to learn more about the most effective application of the supplier’s products.

22.2 Consultants

In a similar manner, independent consultants can provide an excellent source of information with which to improve the security program. They often have a range of experience that spans many products and technologies, and have had the opportunity to observe what works and doesn’t work in various environments. Take care to select a consultant who has relevant experience in a similar or related industry or situation, because this experience can have a significant influence on the nature of the final plan.

22.3 Integrators

Integrators bring knowledge derived from practical experience in a variety of projects. Similar to the projects and services people within the supplier organization, they are an excellent source of information when answering various types of “how to” questions. Verify that all integrators used have experience with cybersecurity issues and details.

22.4 User Groups

Various types of user groups are often overlooked as sources of knowledge and experience. Participating in a customer user group sponsored by your system supplier can quickly provide access to other people with similar interests, needs, and challenges. Most of these groups are based on the implicit principle of open sharing of knowledge and require only modest time commitments.

Copyright 2004 ISA. All rights reserved.

23 Participate in Industry Forums and Development Programs

Periodic reviews and updates should be provided to adapt to changing threats and user needs and incorporate improving electronic security technology.

The plan provides for participation in appropriate industry groups and forums. These groups include sector-lead organizations, standards organizations, supplier organizations, and other groups that provide knowledge sharing on how systems have been compromised, response approaches, and successful programs, plans, and technologies.

Beyond user groups focused on a particular product or supplier, there are a wide variety of industry groups and forums available that can provide information and assistance. A complete list is well beyond the scope of this document, but some of the most significant are listed below.

23.1 ISA—The Instrumentation, Systems, and Automation Society

ISA established Standards and Practices Committee ISA-SP99 with the express intent of developing guidance to help stakeholders provide secure Manufacturing and Control Systems that are not vulnerable to electronic or network-based intrusion and failures. ISA committee membership is encouraged to provide representative expertise from the user, supplier, and academic communities.

23.2 U.S. National Institute of Standards and Technology (NIST)

The Process Control Security Requirements Forum (PCSRF) was developed by NIST with the goal of sharing information in this area and developing standards that will provide secure Manufacturing and Control Systems. It provides another means of information sharing and a group to work with that is interested in developing standards.

NIST is developing a testbed to study performance measures and tests for Manufacturing and Control System security products to determine if particular time-sensitive requirements can be met. The testbed includes emulations of water distribution and bottling plants so that the testing includes as much of the intended physical environment as possible.

23.3 North American Electric Reliability Council (NERC)

NERC provides several industry information sharing services and programs for the electric utility industry. The web site is listed in section 24 below.

23.4 Chemical Industry Data Exchange (CIDX)

CIDX has recently formed a business unit devoted to the subject of cyber security in the chemical industry. This group will promote education, adoption of standards, and technology development.

23.5 Institute of Electrical and Electronics Engineers (IEEE)

The IEEE Power Engineering Society (PES) has several committees addressing cybersecurity.

23.6 International Electrotechnical Commission (IEC)

IEC TC57 Working Group 15 (Data and Communication Security) is addressing cybersecurity of control center and substation communications. IEC TC65 (Industrial Process Measurement and Control) will be addressing cybersecurity.

Copyright 2004 ISA. All rights reserved.

23.7 International Council on Large Electric Systems (CIGRE)

Advisory Group D2.02 has formed a working group, Information Security in Power Utilities.

23.8 U.S. Department of Energy National SCADA Test Bed Program

The U.S. Department of Energy's Office of Energy Assurance has recognized the need for a National Laboratory-based SCADA test bed. Both Sandia National Laboratory and the Idaho National Engineering and Environmental Laboratory will be involved in developing this national test bed with industry participation. The test bed will focus on identifying SCADA and process control system security vulnerabilities and then developing and validating solutions to improve the resilience of critical infrastructures.

23.9 Process Control System Cyber Security Forum (PCSRF)

This subscription forum was established to meet the complex, growing, and increasingly urgent security threats and vulnerabilities of process control systems. It is sponsored by the U.S. National Institute of Standards and Technology (NIST). The forum brings together infrastructure industries, process control system vendors, services providers, government and regulatory stakeholders charged with protecting critical infrastructures and other industries reliant on networked process control systems. The forum relies on a collaborative, information-sharing environment to develop and share security solutions.

The PCSRF's roles in Manufacturing and Control Systems security include:

- Develop protection profiles for security features that new equipment will be built with.
- Future solutions for new equipment and system installations.
- System certification through independent testing.
- Including security considerations in the specification, procurement, and assurance areas of the industrial process control systems lifecycle.
- Test bed to validate standards and to develop performance and conformance test methods.

24 Bibliography and References

Much of the information in this document has been based on readily available information including various existing security-focused Web sites. This technical report emphasizes the need to filter these guidelines to ensure that they do not unacceptably impact system functionality.

Most of the approaches and information are IT-focused, which explains the statement in section 1 to apply all of this information carefully, always considering the impact on Manufacturing and Control Systems functionality. In addition, some of the referenced information is not complete or is flawed in its application to Manufacturing and Control Systems. Again, it must be used carefully to determine the impact on Manufacturing and Control Systems functionality.

The following references provide additional information and details concerning security recommendations:

- ANSI/ISA-95.00.01-2000, Enterprise-Control System Integration Part 1 : Models and Terminology (IEC/ISO 62264-1). (www.isa.org/standards/).

Copyright 2004 ISA. All rights reserved.

- ANSI/ISA-95.00.02-2001, Enterprise-Control System Integration Part 2 : Object Model Attributes. (IEC/ISO draft 62264-2). (www.isa.org/standards/).

- U.S. National Strategy to Secure Cyberspace (http://www.whitehouse.gov/pcipb/cyberspace_strategy.pdf)

- Critical Infrastructure Protection: Cybersecurity of Industrial Control Systems, U.S. NIST. (http://www.mel.nist.gov/proj/cip.htm)

- Process Control Security Requirements Forum (PCSRF), U.S. NIST. (http://www.isd.mel.nist.gov/projects/processcontrol/)

- National Infrastructure Assurance Partnership, U.S. NIST and U.S. NSA. (http://niap.nist.gov/)

- Computer Security Resource Center, U.S. NIST. (http://csrc.nist.gov/)

- CIAO - Critical Infrastructure Assurance Office. (http://www.ciao.gov/)

- The Twenty Most Critical Internet Security Vulnerabilities, The SANS Institute. (http://www.sans.org/top20.htm)

- North American Electric Reliability Council (NERC), (http://www.nerc.com)

- Critical Infrastructure Protection Advisory Group (CIPAG), NERC. (http://www.nerc.com/~filez/cipfiles.html)

- U.S. Federal Energy Regulatory Commission (FERC), (http://www.ferc.gov)

- NOPR on Standard Market Design, U.S. FERC. (http://www.ferc.gov/Electric/RTO/Mrkt-Strct-comments/discussion_paper.htm)

- U.S. Department of Energy (DOE). 21 Steps to Secure Your SCADA Network. (http://oea.dis.anl.gov/home.htm)

- Oil and Natural Gas - National Petroleum Council (https://www.pcis.org/getDocument.cfm?urlLibraryDocID=30)

- Chemicals - US Chemicals Sector Cyber-Security Information Sharing Forum. (https://www.pcis.org/getDocument.cfm?urlLibraryDocID=37)

- Critical Infrastructure Protection National Plan Input, Water Sector—The Association of Metropolitan Water Agencies. (https://www.pcis.org/getDocument.cfm?urlLibraryDocID=27)

- Safeguarding IEDs, Substations, and SCADA Systems Against Electronic Intrusions, P. Oman, E. Schweitzer III, J. Roberts, (http://www.selinc.com/techpprs/6118.pdf)

- The Common Criteria ISO/IEC 15408—The Insight, Some Thoughts, Questions, and Issues, A. Aizuddin. (http://www.niser.org.my/resources/common_criteria.pdf)

- The National Infragard Program, U.S. FBI. (http://www.infragard.net/)

Copyright 2004 ISA. All rights reserved.

- U.S. Dept. of Homeland Security, (http://www.dhs.gov/)

- Information Technology Information Sharing and Analysis Center, (https://www.it-isac.org/)

- Water Information Sharing and Analysis Center, (http://www.waterisac.org/)

Copyright 2004 ISA. All rights reserved.

Annex A — Sample Policies and Procedures Document

This annex provides an *example* of one entity's approach to a Manufacturing and Control System Network Security Policies and Practices document. While it provides the type of guidance that is recommended in ANSI/ISA-TR99.00.02-2004, please note that it contains references, limits, values, and terminology that are *specific* to that entity and may be different from other user, owner, or entity requirements. Some acronyms and references may also be different from those used in ISA documents.

Every Manufacturing and Control System user, owner, or entity needs to develop a program, including procedures, practices, operational policies, standards, training, and other specific activities, incorporating the guidance and subject matter identified in ISA-99.00.02-2004 and tailored to the specific user's, owner's, or entity's hardware and software and existing organizational and programmatic requirements.

Manufacturing and Control System Network Security Operational Policies and Recommended Practices

October 200X

Ver. 2.0 1/03/0X

Notice

The material in this report is believed accurate for the intended use of these recommended practices. The material itself does not infringe any U.S. patents. No further warranty is expressed or implied.

Copyright 2004 ISA. All rights reserved.

Contents

Introduction 77

Purpose 77
Contributors 77
MCN Security Mandatory Operational Policies 78

General MCN Connectivity 78
Architecture 79
Data Encryption 79
Virus Detection 79
Inbound Traffic to the MCN 80
Outbound Traffic from the MCN 80
Wireless Communication on the MCN 80
MCN Security Recommended Practices 81

General MCN Considerations 81
Virus Detection 81
Inbound Traffic to the MCN 82
Outbound Traffic from the MCN 83
Miscellaneous Recommendations 84

Copyright 2004 ISA. All rights reserved.

Introduction

Purpose

This document presents the mandatory and recommended set of practices for working with Manufacturing and Control Network (MCN) security. These recommendations are the result of collaboration between Engineering, IT, and the Security organizations.

All MCNs must conform to the mandatory operational policies listed. A variance process must be followed for any diversion from mandatory policies.

Contributors

Some company proprietary information has been removed from this document to ensure corporate security.

Copyright 2004 ISA. All rights reserved.

MCN Security Mandatory Operational Policies

The following policies must be followed for all MCNs. A variance process must be followed for any diversion from mandatory policies.

Sites that are currently using non-guideline firewall equipment and want to expand the installation must also use the variance process. While it doesn't make sense for early adopters currently using non-guidelined firewalls to change equipment, they may want to migrate to corporate guidelined equipment, as firewalls need to be replaced in the future.

General MCN Connectivity

1. All high and medium-risk manufacturing and control networks must be firewalled or disconnected from any external networks (site, corporate, and/or public networks).
    a. High-risk manufacturing and control network installations are to be completed with haste.
    b. Medium-risk manufacturing and control network installations are to be completed promptly after securing the high-risk installations..
2. All manufacturing and control network firewalls must be:
    a. Configured according to a set of published standards established company-wide.
    b. Centrally monitored in accordance with "Corporate Firewall Monitoring Guidelines" for health and security by the Corporate Firewall Monitoring/Support Entity.
    c. Centrally backed-up by the Corporate Firewall Monitoring/Support Entity and have a viable disaster recovery process documented.
    d. Centrally supported by the Corporate Firewall Monitoring/Support Entity and have a documented Escalation, Reporting, and Change Management process in place.
3. Brand XXX, Model NNN firewalls are the current guideline firewall for manufacturing control networks.

Copyright 2004 ISA. All rights reserved.

Architecture

1. The manufacturing and control network **must be** completely separated from the corporate network (e.g., the MCN and local area network (LAN) cannot share the same switching infrastructure).
    a. All MCN-connected devices will be addressed using approved company registered addressing.
    b. All devices on the MCN must be on a separate subnet from the rest of the site LAN devices.
    c. The MCN can be a full Class C subnet of 254 nodes or a portion of the range based upon natural bit boundaries of the subnet mask.
    d. Devices on the LAN accessing nodes on the MCN must use the proper subnet mask, as defined by the node's gateway mask. (The 255.0.0.0 subnet mask will not work.)
    e. Network Address Translation (NAT) will not be used on the MCN.
2. No modems shall be directly connected to the MCN or a MCN node for remote access to the MCN devices by users and other support personnel.

Data Encryption

1. All MCN data traveling over the public networks (intranet) must be encrypted. The standard corporate VPN technology must be employed.

Virus Detection

1. Virus detection software shall be run on all Windows-based devices on the MCN. Virus definition files must be kept up-to-date.

Copyright 2004 ISA. All rights reserved.

Inbound Traffic to the MCN

1. All interactive users connected to the LAN who need to access devices on the MCN must use token based two factor authentication to authenticate at the MCN firewall.
2. Receiving e-mail is not allowed on any MCN device.
3. HTTP Proxy must be setup on the MCN firewall to block all inbound scripts.
4. Inbound unauthenticated SNMP commands such as “Gets” and “Sets” are prohibited from the LAN and WAN to MCN devices.
5. The following Telnet practices must be followed:
    - Interactive token based two factor authenticated Telnet session commands from the LAN and WAN to the MCN are allowed.
    - Non–interactive inbound Telnet session commands from the LAN and WAN to the MCN are prohibited.
6. The following FTP practices must be followed:
    - Inbound anonymous FTP session commands (interactive or application-to-application) are prohibited from the LAN and WAN to the MCN.
    - Inbound user identified (interactive or application-to-application) FTP session commands from the LAN and WAN to the MCN are allowed.
    - Interactive token based two factor authenticated anonymous FTP session commands from the LAN and WAN to the MCN are allowed.

Outbound Traffic from the MCN

1. MCN devices shall not be allowed to access the Internet through the firewall.

Wireless Communication on the MCN

1. Wireless devices using 802.11b communications standard shall not be used on manufacturing and control networks.

Copyright 2004 ISA. All rights reserved.

MCN Security Recommended Practices

The following security guidance is strongly recommended as complimentary practices to the mandatory policies identified in the preceding section. These practices should be followed to ensure the safety of the Manufacturing and Control Network.

General MCN Considerations

1. Operator console activities should be limited to those required to perform the job. Non-essential applications, such as Lotus Notes or Outlook for user E-mail or other Microsoft Office desktop applications, should not be installed on MCN devices.
2. In general, token based two factor authentication is not required for users located on the MCN in order to access other devices on the MCN.
3. Control room operators do not need to use a Windows logon or token based two factor authentication to gain access to the consoles used to control the process. Physical security practices must be employed to restrict access to designated personnel.

Virus Detection

1. Brand YYY is the guidelined and preferred virus detection software for use within the company. Brand ZZZ Anti-virus is an acceptable alternative when Brand YYY is not compatible with the critical MCN applications.
2. Virus definition files for the MCN devices should be obtained from a corporate intranet server, not directly from the Internet. (In order to minimize security vulnerabilities, a recommended strategy is to use FTP to copy the virus definition files from a LAN-connected device to a single device on the MCN, then use this device to distribute the definition files to the other MCN nodes.) The files should be virus checked before copying them to the MCN.

Copyright 2004 ISA. All rights reserved.

Inbound Traffic to the MCN

1. Inbound traffic through the MCN firewall should be limited to essential communications only.

    a. All non-interactive inbound traffic from the LAN to the MCN will be source and destination restricted by service and port using static firewall rules.

    b. Interactive users on the LAN that have successfully token based two factor authenticated at the MCN firewall will be destination restricted by service and port using dynamic rules. These interactive users may be further restricted at the application level by Windows authorization mechanisms and/or access control lists.

    c. Remote support personnel connecting over the Internet must run the corporate VPN connection client and authenticate using the token based two factor authentication scheme in order to connect to the corporate network. (Mandatory Policy)

    d. Remote support personnel connecting to the corporate network via dial-in modem must authenticate using token based two factor authentication to gain access to network resources. They will be required to authenticate a second time to gain access to the MCN using token based two factor authentication.

    e. Remote Procedure Call (RPC)-type communications like DCOM that dynamically open a wide range of ephemeral ports (#1024 – #65535) should be avoided. Restrict, if possible, by making registry modifications or limit port ranges within the application.

    f. Web servers should be located on the LAN rather than on the MCN side of the firewall. If a Web server is located on the MCN, standard browser clients on the LAN may connect to the MCN-based Web server, provided the application does not utilize any Java scripts. All inbound HTTP scripts must be blocked at the MCN firewall.

2. Support personnel moving files from the LAN to the MCN should use FTP rather than Windows Copy to move files.

3. Avoid passing Domain Name Services (DNS) between the LAN and MCN. However, there may not be any workaround if a Primary Domain Controller (PDC) is not located on the MCN. WINS is the method typically used for NetBIOS name resolution. This issue can be resolved by using the LMHOST file and removing the WINS entry in the network configuration.

Copyright 2004 ISA. All rights reserved.

4. Inbound traffic from one MCN to another on the same firewall should be limited to essential communications only.

    a. All non-interactive inbound traffic from one MCN to another will be source and destination restricted by service and port using static firewall rules.

    b. Inbound interactive users from another MCN will employ token based two factor authentication and be destination restricted by service and port using dynamic firewall rules.

Outbound Traffic from the MCN

1. Outbound traffic through the MCN firewall should be limited to essential communications only.

    a. All non-interactive outbound traffic from the MCN to the LAN will be source and destination restricted by service and port using static firewall rules.

    b. Interactive users (no logon or authentication) on MCN-connected devices do not need to use token based two factor authentication to egress through the MCN firewall to resources on the LAN. Communication will be source and destination restricted by service and port using static firewall rules.

    c. Special administrative users may use token based two factor authentication to temporarily egress from the MCN. Dynamic rules will be used to provide temporary egress to LAN-connected devices. Dynamic rules may not be in violation of the mandatory Inbound and Outbound Policies.

2. Outbound Simple Mail Transport Protocol (SMTP) mail communications from the MCN to the LAN is acceptable.

3. Mapped drives across the MCN firewall should be avoided.

4. Outbound traffic from one MCN to another MCN on the same firewall should be limited to essential communications only.

    a. All non-interactive outbound traffic from one MCN to another MCN will be source and destination restricted by service and port using static firewall rules.

    b. Outbound interactive users from one MCN to another MCN will require token based two factor authentication and be destination restricted by service and port using dynamic rules.

5. Time service communication to a LAN time server may traverse the MCN firewall to synchronize time on MCN. Communication will be source and destination restricted by service and port.

Copyright 2004 ISA. All rights reserved.

Miscellaneous Recommendations

1. Areas and businesses should develop a documented Change Management process with appropriate signoff by safety, security, and manufacturing personnel. The Firewall Monitoring/Support Entity shall be notified in advance of any ruleset changes that are expected to trigger a firewall alarm notification event.

2. Areas must provide updated escalation and contact information to the central Firewall Monitoring/Support Entity.

3. The site IT security policy must include the manufacturing and control security practices employed at the sites. The practices should contain a periodic review of authorized users configured on the MCN firewall and their associated rules to address the vulnerabilities created by changing roles.

4. Manufacturing Support Systems that download values directly to the DCS should typically be located on the MCN rather than the LAN. Placing the manufacturing support system behind the MCN firewall can add an additional level of protection to the manufacturing support system and its data. This assessment needs to be a site-by-site decision, based upon how the specific manufacturing support system and DCS interface is physically connected, the capability of the interface, how the interface is presently configured/setup, how the interface can be re-configured, and how the systems are used.

5. Special HMI application clients may employ proprietary security mechanisms to authorize or control access of users to information servers. These proprietary security mechanisms may not function correctly through the MCN firewall. Special care must be taken to ensure that users can securely employ any special proprietary security mechanisms within the constraints of the stringent MCN security policies and practices.

7. VAX-based manufacturing and shop floor applications may contain information that is not as critical as the regulatory process control systems, but is more business critical than other general LAN based servers. Sites should consider implementing the token based two factor authentication agent to authenticate users in order to reduce the vulnerability of these systems.

8. A CD or DVD burner installed on a MCN device may be a viable alternative to backup key files rather than opening up the MCN firewall to copy files over the MCN network to the LAN.

Copyright 2004 ISA. All rights reserved.

9. Like control room consoles, there may be some special function HMI(human machine interface) nodes on the manufacturing floor that are shared amongst several operators to perform essential production tasks. These operators will not need to login or use token based two factor authentication for authentication in order to gain access to the HMI nodes. Physical controls and administrative practices will be employed to limit access to these devices by authorized operators. Examples include shared mix stations, spinning doff stations, packing stations, etc.

Copyright 2004 ISA. All rights reserved.

This page intentionally left blank.

Annex B — A Sample Vulnerability Assessment Procedure

The ISA-SP99 committee recognizes this topic as important and will address it in a future revision of this Technical Report.

Annex C —Integrating Security into Supplier Practices

The ISA-SP99 committee recognizes this topic as important and will address it in a future revision of this Technical Report.

Copyright 2004 ISA. All rights reserved.

This page intentionally left blank.

Developing and promulgating sound consensus standards, recommended practices, and technical reports is one of ISA's primary goals. To achieve this goal the Standards and Practices Department relies on the technical expertise and efforts of volunteer committee members, chairmen and reviewers.

ISA is an American National Standards Institute (ANSI) accredited organization. ISA administers United States Technical Advisory Groups (USTAGs) and provides secretariat support for International Electrotechnical Commission (IEC) and International Organization for Standardization (ISO) committees that develop process measurement and control standards. To obtain additional information on the Society's standards program, please write:

ISA
Attn: Standards Department
67 Alexander Drive
P.O. Box 12277
Research Triangle Park, NC 27709

ISBN: 1-55617-889-1